



Cyber Security (CYBER); CRA; Cybersecurity requirements for personal wearable products to be worn or placed on a human body that have a health monitoring purpose and for personal wearable products that are intended for the use by and for children

Exercising one of the Principles of international standardization - Openness - and taking it to a different level, ETSI is piloting informal public consultations of the vertical standards in support of the Cyber Resilience Act at a much earlier stage than it is usual in the standardization world. In this context, please keep in mind that the standard draft herein is an INTERIM DRAFT, which expectably will be subject to substantial changes before its target publication date in the second semester of 2026.

Disclaimer

This **INTERIM DRAFT** document is provided for information and is for future development work within the ETSI Technical Committee CYBER EUSR Working Group (CYBER-EUSR) only. ETSI and its Members accept no liability for any further use/implementation of this Specification. Approved and published specifications and reports shall be obtained exclusively via the ETSI Documentation Service at <http://www.etsi.org/standards-search>

Commenting guidelines

Your comments to improve this early draft are very welcomed. To ensure the effectiveness of your contribution, please make sure to include the following elements in your comment:

1. Clear identification of the section of the draft your comment is referring to.
2. Objective proposal to delete content, add content or substitute content.
3. Concrete contribution (exact content you suggest including in the draft as an addition to, or in substitution of, existing content).
4. Brief rationale to justify the proposal (e.g. why the suggested content should be added an/or the existing content should be deleted or substituted). Please note that comments without concrete contributions will be noted but not acted upon by ETSI CYBER-EUSR. We trust and value your expertise and therefore expect you to take this opportunity to proactively contribute to solving the issues you find while analysing this early draft.

How to comment

To comment or provide feedback on the present interim draft please visit: [STAN4CRA / EN 304 634 Personal wearables · GitLab](#) and submit your comments as “issues” following the guidelines provided on this site.

Alternatively, you may also send your comments to: cybersupport@etsi.org using the “[ETSI Commenting Format for Open Consultation.xlsx](#)” available in <https://docbox.etsi.org/CYBER/EUSR/Open>

Reference

DEN/CYBER-EUS-003

Keywords

CRA; Cybersecurity, wearables

0

ETSI

650 Route des Lucioles
F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B
Association à but non lucratif enregistrée à la
Sous-Préfecture de Grasse (06) N° w061004871

Important notice

The present document can be downloaded from the
[ETSI Search & Browse Standards](#) application.

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on [ETSI deliver](#) repository.

Users should be aware that the present document may be revised or have its status changed,
this information is available in the [Milestones listing](#).

If you find errors in the present document, please send your comments to
the relevant service listed under [Committee Support Staff](#).

If you find a security vulnerability in the present document, please report it through our
[Coordinated Vulnerability Disclosure \(CVD\)](#) program.

Notice of disclaimer & limitation of liability

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.

No recommendation as to products and services or vendors is made or should be implied.

In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided "AS IS" with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

Copyright Notification

Reproduction is only permitted for the purpose of standardization work undertaken within ETSI.
The copyright and the foregoing restrictions extend to reproduction in all media.

© ETSI 2026.
All rights reserved.

Contents

1	Intellectual Property Rights.....	6
2	Foreword.....	6
3	Modal verbs terminology	7
4	1 Scope.....	7
5	2 References.....	7
6	2.1 Normative references.....	7
7	2.2 Informative references.....	7
8	3 Definition of terms, symbols and abbreviations.....	8
9	3.1 Terms.....	8
10	3.2 Symbols.....	11
11	3.3 Abbreviations.....	11
12	4 Product context.....	12
13	4.1 General.....	12
14	4.2 Intended purpose and reasonably foreseeable use	12
15	4.2.1 Wearable that have a health monitoring purpose	12
16	4.2.2 Wearable that are intended for the use by and for children.....	13
17	4.3 Product functions.....	13
18	4.3.1 Health monitoring functionalities (essential functionalities).....	13
19	4.3.2 Location-based functionalities (essential functionalities)	14
20	4.3.3 Notification functionalities (essential functionalities).....	14
21	4.3.4 Input commands from user or other connected devices (supporting functionalities).....	14
22	4.3.5 Data logging and storage (supporting functionalities)	14
23	4.3.6 General functionalities (supporting functionalities).....	15
24	4.3.7 Data assets.....	15
25	4.4 Product Architecture.....	15
26	4.4.1 Wearable that have a health monitoring purpose architecture.....	16
27	4.4.2 Wearable that are intended for the use by and for children architecture	17
28	4.5 Operational Environment.....	18
29	4.6 Interfaces.....	19
30	4.7 Users.....	19
31	4.7.1 End-Users.....	19
32	4.7.2 Manufacturers	19
33	4.8 Use cases profiles	19
34	4.8.1 Use case profile for basic impact essential functionalities	19
35	4.8.2 Use case profile for medium impact essential functionalities	19
36	4.8.3 Use case profile for high impact essential functionalities	20
37	4.9 Security Profiles.....	20
38	5 Requirements specifications.....	20
39	5.1 Product's technical requirements specifications.....	20
40	5.1.1 Known exploitable vulnerabilities.....	20
41	5.1.1.1 [NKEV] No known exploitable vulnerabilities	20
42	5.1.1.2 [NKEV-SUM] Secure software update mechanism	20
43	5.1.1.3 [NKEV-SUM-PROVIDE] Secure software update mechanism for core components	20
44	5.1.2 Default configuration	21
45	5.1.3 Authentication and access control mechanisms	21
46	5.1.3.1 [ACM-FH] Access control for functions whose use can cause harm.....	21
47	5.1.3.2 [AUM-FH] Authentication for functions whose use can cause harm.....	22
48	5.1.3.3 [AUTHZ-LP] Least privilege in authorization policies.....	22
49	5.1.3.4 [AUTHZ-R] Revocability of granted permissions	23
50	5.1.4 Integrity protection.....	23
51	5.1.4.1 [INT-SWPCK] Software package verification.....	23
52	5.1.4.2 [INT-COM] Communication of integrity relevant data.....	23
53	5.1.5 Confidentiality protection	24
54	5.1.5.1 [CONF-SSM] Confidentiality protecting persistent storage for confidential data	24

56	5.1.5.2	[CONF-COM] Communication of confidential data	24
57	5.1.6	Data minimization	24
58	5.1.6.1	[DMIN-DJST] Documented justification of processed data	24
59	5.1.7	Availability protection	25
60	5.1.7.1	[AVAI-TIME-RECO-POW] Restoration after loss of power	25
61	5.1.7.2	[AVAI-TIME-NETW] Local operation	25
62	5.1.7.3	[AVAI-TIME-RECO-NETW] Restoration after loss of network connection	25
63	5.1.7.4	[AVAI-TIME-OUTA-NOT] Notify non-availability	25
64	5.1.7.5	[AVAI-TIME-PREV-NOT] Notify upcoming limitation	25
65	5.1.7.6	[AVAI-TIME-PREV-PRIO] Network prioritization	25
66	5.1.7.7	[AVAI-TIME-PREV-PRIO] Resource prioritization	25
67	5.1.7.8	[AVAI-TIME-IMP-AMP] Amplification control	26
68	5.1.7.9	[AVAI-TIME-DOS-RATE] Incoming rate limiting	26
69	5.1.7.10	[AVAI-UPD-SCHEDULE] Scheduling of updates	26
70	5.1.8	Impact minimization	26
71	5.1.9	Limit attack surface	26
72	5.1.9.1	[LAS-INVAL] Validation of external data input	26
73	5.1.9.2	[LAS-INSAN] Sanitization of external data input	26
74	5.1.9.3	[LAS-PHY-INF] Only necessary physical interfaces	26
75	5.1.9.4	[LAS-LOGIC-INF] Only necessary logical interfaces active by default	26
76	5.1.9.5	[LAS-APP] Only necessary apps by default	26
77	5.1.10	Logging and monitoring mechanisms	26
78	5.1.11	Deletion mechanisms	27
79	5.1.12	Other product's technical requirements specifications	27
80	5.2	Requirements specifications for vulnerability handling activities related to the product	27
81	6	Assessing for compliance with requirements	27
82	Annex A (informative): Relationship between the present document and the requirements of EU		
83	Regulation 2024/2847		
84	Annex B (informative): Guidance for the application of the present document		
85	Annex C (informative): Information on the methodology for the assessment of cybersecurity risks		
86	used to develop the present document		
87	C.1	Guidance for determining impact classes	32
88	C.1.1	General	32
89	C.1.2	Confidential data	32
90	C.1.3	loss sensitive data	32
91	C.1.4	time sensitive data and time sensitive function	33
92	C.1.5	integrity relevant data and integrity relevant function	33
93	Annex D (normative): Relationship between specific data and functions assets covered by the		
94	present document to impact classes for generic asset categories		
95	D.1	Identifier	35
96	D.2	Data assets	37
97	D.3	Function assets	37
98	D.3.1	Functions whose use can cause harm	38
99	Annex E (normative): Protection measures		
100	E.1	Identifier	39
101	E.2	access control mechanism's strength	40
102	E.3	authentication mechanism strength	40
103	E.3.1	AUM-FH Authentication for functions whose use can cause harm	40
104	E.3.1.1	General	40
105	E.3.1.2	Authentication strength level basic	40
106	E.3.1.3	Authentication strength level normal	40
107	E.3.1.4	Authentication strength level enhanced	40

108	E.3.1.5	Authentication strength level strong.....	41
109	E.3.2	Assessment for authentication mechanism strength	41
110	E.3.2.1	Assessment criteria regarding the protection against limited presentation attacks.....	41
111	E.3.2.2	Assessment criteria regarding the protection against targeted presentation attacks	42
112	E.3.2.3	Assessment criteria regarding the protection against elaborate presentation attacks	43
113	E.3.2.4	Assessment criteria regarding the protection against limited brute force attacks.....	43
114	E.3.2.5	Assessment criteria regarding the protection against targeted brute force attacks	44
115	E.3.2.6	Assessment criteria regarding the protection against automated brute force attacks	45
116	E.3.2.7	Assessment criteria regarding the protection against presentation attacks.....	45
117	E.3.2.8	Assessment criteria regarding the protection against elaborate brute force attacks	46
118	E.3.2.9	Assessment criteria regarding the protection against automated security token spoofing attacks	47
119	E.3.2.10	Assessment criteria regarding the protection against targeted security token spoofing attacks	47
120	E.3.2.11	Assessment criteria regarding the protection against elaborate security token spoofing attacks	48
121	E.3.2.12	Assessment criteria regarding the protection against replay attacks	48
122	E.3.2.13	Assessment criteria regarding the protection against PitM attacks	49
123	E.4	confidentiality protection strength.....	50
124	E.4.1	CONF-SSM Confidentiality protecting persistent storage for confidential data	50
125	E.4.1.1	General	50
126	E.4.1.2	confidential persistent storage strength level basic	50
127	E.4.1.3	confidential persistent storage strength level normal	50
128	E.4.1.4	confidential persistent storage strength level enhanced	50
129	E.4.1.5	confidential persistent storage strength level strong.....	50
130	E.5	confidentiality protection strength.....	51
131	E.5.1	CONF-COM Communication of confidential data.....	51
132	E.5.1.1	General	51
133	E.5.1.2	communication of confidential data protection strength level basic	51
134	E.5.1.3	communication of confidential data protection strength level normal	51
135	E.5.1.4	communication of confidential data protection strength level enhanced.....	51
136	E.5.1.5	communication of confidential data protection strength level strong.....	51
137	E.6	integrity protection strength.....	52
138	E.6.1	INT-SWPCK Software package verification	52
139	E.6.1.1	General	52
140	E.6.1.2	software package integrity verification strength level basic	52
141	E.6.1.3	software package integrity verification strength level normal.....	52
142	E.6.1.4	software package integrity verification strength level enhanced	52
143	E.6.2	INT-COM Communication of integrity relevant data.....	52
144	E.6.2.1	General	52
145	E.6.2.2	communication of integrity relevant data protection strength level basic	52
146	E.6.2.3	communication of integrity relevant data protection strength level normal	52
147	E.6.2.4	communication of integrity relevant data protection strength level enhanced.....	53
148	E.6.2.5	communication of integrity relevant data protection strength level strong.....	53
149	Annex F (informative): Relationship between the present document and the requirements of EU		
150	Regulation 2024/2847.....		54
151	Annex G (informative): Relationship between the present document and the covered/not covered		
152	cybersecurity risks		56
153	Annex H (informative): Change history		
154	History		58
155			
156			

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *"Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards"*, which is available from the ETSI Secretariat. Latest updates are available on the [ETSI IPR online database](#).

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

BLUETOOTH® is a trademark registered and owned by Bluetooth SIG, Inc.

Foreword

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Security (CYBER), and is now submitted for the combined Public Enquiry and Vote phase of the ETSI Standardisation Request deliverable Approval Procedure (SRdAP).

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Working Group for EUSR (CYBER-EUSR), and is now submitted for the combined Public Enquiry and Vote phase of the ETSI Standardisation Request deliverable Approval Procedure (SRdAP).

The present document has been prepared under the Commission's standardisation request C(2025) 618 final to provide one voluntary means of conforming to the requirements of Regulation (EU) No 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

Proposed national transposition dates	
Date of latest announcement of this EN (doa):	3 months after ETSI publication
Date of latest publication of new National Standard or endorsement of this EN (dop/e):	6 months after doa
Date of withdrawal of any conflicting National Standard (dow):	18 months after doa

Modal verbs terminology

In the present document "shall", "shall not", "should", "should not", "may", "need not", "will", "will not", "can" and "cannot" are to be interpreted as described in clause 3.2 of the [ETSI Drafting Rules](#) (Verbal forms for the expression of provisions).

"must" and "must not" are **NOT** allowed in ETSI deliverables except when used in direct citation.

1 Scope

The present document specifies activities, technical characteristics, cybersecurity requirements and corresponding assessment criteria for personal wearable products to be worn or placed on a human body:

- 1) that have a health monitoring purpose; or
- 2) that are intended for the use by and for children

within the product context described in clause 4.

The present document covers those products to demonstrate compliance with essential cybersecurity requirements in the Regulation (EU) 2024/2847 [i.1] under the conditions identified in annex [A](#).

2 References

2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

Referenced documents which are not found to be publicly available in the expected location might be found in the [ETSI docbox](#).

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

- | | |
|-----|--|
| [1] | prEN 40000-1-3: "Cybersecurity requirements for products with digital elements - Vulnerability Handling". |
| [2] | European Union Agency for Cybersecurity, European Cybersecurity Certification Group - Sub-group on Cryptography - Agreed Cryptographic Mechanisms. |

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long-term validity.

229 The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader's
230 understanding but are not required for conformance to the present document.

231 [i.1] [Regulation \(EU\) 2024/2847](#) on horizontal cybersecurity requirements for products with digital
232 elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive
233 (EU) 2020/1828 (Cyber Resilience Act)

234 [i.2] [Commission Implementing Regulation \(EU\) 2025/2392](#) of 28 November 2025 on the technical
235 description of the categories of important and critical products with digital elements pursuant to
236 Regulation (EU) 2024/2847 of the European Parliament and of the Council.

237 [i.3] [Standardisation request M/606 - C\(2025\)618](#): "Commission Implementing decision of 3.2.2025 on
238 a standardisation request to the European Committee for Standardisation (CEN), the European
239 Committee for Electrotechnical Standardisation (Cenelec) and the European Telecommunications
240 Standards Institute (ETSI) as regards products with digital elements in support of Regulation (EU)
241 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal
242 cybersecurity requirements for products with digital elements and amending Regulations (EU) No
243 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act)".

244 [i.4] CEN/CLC JT013095:2026 (CEN/CLC prEN 40000-1-1): "Cybersecurity requirements for
245 products with digital elements – Vocabulary".

246 3 Definition of terms, symbols and abbreviations

247 3.1 Terms

248 For the purposes of the present document, the terms and definitions given in Regulation (EU) 2024/2847 [i.1],
249 prEN 40000-1-1 [i.4] and the following apply:

250 **access control policy:** policy that describes the access rights of entities on product's data and functions

251 **access control policy data:**

252 **access control mechanism:** product function that enforces an access control policy

253 **activity data:** data asset that describes physical movements, behaviours or activity patterns to monitor the personal
254 fitness level of humans

255 **actuator:** device or component able to affect its physical environment as a result of command inputs

256 **EXAMPLE:** electric motor, heater, etc.

- 257 **adjacent communication:** public communication limited to a logically adjacent topology or ingoing/outgoing
258 communication to private networks
- 259 **audio input data:** data asset that represents audio information captured by the product
- 260 **audio input function:** product function that converts audio signals into data
- 261 **audio output function:** product function that converts data into audio signals
- 262 **authorization policy:** policy that describes the access rights of entities on product's data and functions
- 263 **authentication mechanism:** product function that verifies an entity's claim
- 264 **authorization policy data:** data asset that contains an authorization policy
- 265 **confidential data:** data asset, whose disclosure can have a negative impact
- 266 **configuration functionality:** product function that allows to change the configuration of product's functions
- 267 **confined operational environment:** physical operational environment, where the geographical location is confined to a
268 specific area
- 269 **connection function:** product function that is used for testing or establishing communication capability via machine
270 interface
- 271 EXAMPLE: ICMP, DHCP Discovery
- 272 NOTE: Communication without user data and without authentication of the communication partner for the
273 purpose of connection establishment
- 274 **controlled mobile operational environment:** mobile operational environment where the user is expected to be
275 constantly carrying the product
- 276 **core software:** any software that abstracts hardware, manages hardware resources and provides interfaces for other
277 software to interact with each other or the core software
- 278 EXAMPLE: A physical MP's operating system, hardware abstraction layer or APIs
- 279 **data:** information in digital form
- 280 **data asset:** asset, that is data processed or stored by the product
- 281 **device location data:** data asset containing information on the geographical information of devices
- 282 **factory reset function:** product function that removes all user data and sets the MP in a factory default state, potentially
283 keeping software updates
- 284 **fully controlled physical operational environment:** physical operational environment, where physical access is fully
285 controlled by the user or trusted persons
- 286 EXAMPLE: Private house or apartment.
- 287 **function asset:** asset, that is a function of the product
- 288 **function trigger input:** input to the RDPSs' or MP's functions provided by:
- 289 • human users, or
- 290 • sensor components of the MP or connected devices, or
- 291 • other devices or services
- 292 **function output:** output of RDPSs' or MP's functions that is:
- 293 • a modification or creation of products' data or functions, or
- 294 • information intended to inform human users, or

- 295 • information intended to inform or control devices or services, or
- 296 • information intended to control actuators, resulting in an action on the physical operational environment
- 297 **function whose use can cause harm:** function asset that is:
 - 298 • a function whose use can impact the availability of other devices, services or networks,
 - 299 • a function whose use can impact the safety or privacy of human user
 - 300 • a function who can communicate confidential data,
 - 301 • a function who can communicate integrity relevant data,
 - 302 • a function who can modify integrity relevant data, or
 - 303 • a function who can modify integrity relevant functions
- 304 **health data:** data asset that indicates information about physiological functions, health condition or physical fitness of
- 305 humans
- 306 **human interface:** interface that is intended to be used by human
- 307 **integrity relevant data:** data asset, whose tampering can have a negative impact
- 308 **integrity relevant function:** function asset, whose tampering can have a negative impact
- 309 **interface:** shared boundary across which the product exchanges information
- 310 **local communication:** ingoing/outgoing communication which requires physical access to a communication partner's
- 311 interface or proximity of the communication partner to the product
- 312 **location data:** data containing geographical information
- 313 **logging mechanism:** product function that logs events
- 314 **logical interface:** interface that does not exist in hardware and can only be used by using another device or a physical
- 315 interface of a product with digital elements
- 316 **logical operational environment:** operational environment describing the accessibility via logical interfaces
- 317 **loss sensitive data:** data asset, whose permanent loss has a negative impact
- 318 **machine interface:** interface that is intended to be used for machine-to-machine communication
- 319 **main product:** product without the remote data processing solution
- 320 **mobile operational environment:** physical operational environment, where the geographical location is changing
- 321 during operation and not confined to a specific area
- 322 NOTE: Physical operational environment of smartphones and wearables
- 323 **network status data:** data asset that describes MPs' or RDPSs' network connections status
- 324 **notification mechanism:** product function that notifies entities on certain events
- 325 **partially controlled physical operational environment:** physical operational environment, that is not a fully
- 326 controlled physical operational environment and either under the control of a limited set of persons or located in an area
- 327 where untrusted physical access is suspicious
- 328 EXAMPLE: Shared area in a house with different apartments or private property where public access is not
- 329 intended.

personal calendar data: data asset that represents information on a personal calendar

personal contact data: data asset that represents personal contact information of entities

personal notes data: data asset that represents personal information other than calendar data or contact data

physical communication: communication that requires manipulation of the communication partner's hardware or the hardware the communication partner runs on

physical interface: interface that is part of the hardware of a product

physical operational environment: operational environment describing the physical accessibility

physical security function: product function which provides function output as reaction to function trigger input related to residential physical security

product: product with digital element

NOTE: In the context of the present document the product is a personal wearable product.

public communication: ingoing/outgoing communication to public networks

public data: data from publicly accessible sources

public data asset: data asset derived from public data

sensor: device or component able to measure characteristics of its physical environment, generating data input representative of its physical environment

EXAMPLE: Blood pressure sensor, heart rate monitor, accelerometer, etc.

software update mechanism: product function that allows to change the product's software

time sensitive data: data asset, where a time delay in availability has a negative impact

time sensitive function: function asset, where a time delay in availability has a negative impact

uncontrolled physical operational environment: physical operational environment, where physical access control on arbitrary untrusted entities cannot be ensured for prolonged time periods and where untrusted physical access is not necessarily suspicious

EXAMPLE: Areas intended for public access

user data: data provided by a user

video input data: data asset that represents video information captured by the product

video input function: product function that converts video signals into data

video output function: product function that converts data into video signals

3.2 Symbols

Void.

3.3 Abbreviations

For the purposes of the present document, the following abbreviations apply:

GPS	Global Positioning System
MP	Main Product
RDPS	Remote Data Processing Solution

4 Product context

4.1 General

Two kinds of products are considered in the present document: wearable that have a health monitoring purpose and wearable that are intended for the use by and for children. As per CRA [i.1], hardware and software products may fall in this category, but most products include a combination of hardware (including sensors and some processing capabilities) and hosted software.

Non-exhaustive examples of wearable that have a health monitoring purpose are:

- smartwatches;
- fitness bands;
- smart glasses
- heart rate monitor,
- smart socks;
- headbands;
- biomechanical shoe insoles;
- skin patches

Wearable that are intended for the use by and for children can be divided in two categories depending to the age of the child. There is a clear separation between the products for babies under 2-year-old, for which the monitoring is much more extensive but without the need of the baby to manage the device, and the preadolescent children where GPS tracking and Parental Control are key functionalities.

Non-exhaustive examples of wearable that are intended for the use by and for preadolescent children are:

- smartwatches with GPS tracking and parental control

Non-exhaustive examples of wearable that are intended for the use by and for babies under 2-year-old are:

- baby monitoring system including:
 - baby smart socks
 - sensor bracelet for breathing monitoring
 - Smart wearable breast pumps
 - Smart pacifiers - with temperature check-ups and GPS tracker

4.2 Intended purpose and reasonably foreseeable use

4.2.1 Wearable that have a health monitoring purpose

The main intended uses of this category of products are:

- 1) the health monitoring which means the continuous collection, analysis and visualization of physiological and health-related data (e.g. heart rate data, blood oxygen levels, stress data or other vital signs) using sensors included in the product;
- 2) the activity tracking which means collecting and analysing (automatically or on demand) data like the number of steps done, distance gone, exertion, intensity and burned calories during activities like walking, jogging, bicycling, swimming, dancing; etc.

Several use cases can be derived from the two main intended uses listed above:

- 1) productivity use cases which involve monitoring of user's activity. Wearable devices track activity such as a step, walking patterns, walking speed, posture, identifying periods of rest and fatigue. Using this information, wearable can raise awareness about the lifestyle patterns, provide scheduled or situation-based notifications (e.g. work breaks, rests, or walks).
- 2) wellness use cases which include monitoring of stress levels, providing medication reminders, monitoring sleep patterns and heart rate patterns, identifying abnormal health events and long-term health trends, supporting better rest and recovery of the human body, supporting hygiene routines (e.g. hand hygiene), and offer safety features (e.g. fall detection and alerts for elderly users).
- 3) fitness and sports use cases which involve monitoring of relevant physiological data to get insights into fitness condition, fitness performance to optimize training and sports tactics.
- 4) safety use cases which involve supporting personal safety and environmental awareness. Wearable devices provide alerts (e.g. fall detection, SOS), notifications (e.g. user fatigue) and share user's location (e.g. to other team members).
- 5) interactive experiences use cases which involve integrated sensory experiences and real-time feedback (e.g. virtual reality, art installations) and educational programs that enhance learning by increasing motivation and engagement. Wearable devices capture physiological data such as body movements, hand movements electroencephalography (EEG), eye tracking, heart rate.

4.2.2 Wearable that are intended for the use by and for children

The main intended uses of this category of products are:

- 1) the health monitoring which means the continuous collection, analysis and visualization of physiological and health-related data (e.g. heart rate data, blood oxygen levels, stress data or other vital signs) using sensors included in the product.
- 2) The location tracking to monitor the children position.
- 3) Parental control to allow children parents to control the child activities on the products.

4.3 Product functions

This clause lists the essential functionalities associated with the product's intended use.

4.3.1 Health monitoring functionalities (essential functionalities)

It includes the physiological data acquisition using sensors, physiological data signal processing, analysis and visualization. Examples of sensors include light source and photodetector, accelerometers, gyroscopes, temperature sensor, skin response sensor, pulse oximeter sensor (SP0₂), skin temperature, skin conductance, non-invasive surface electrodes, microphones, piezoelectric sensors, smart glasses.

Examples of health monitoring functionalities include:

- the health monitoring which means the continuous collection, analysis and visualization of physiological and health-related data (e.g. heart rate data, blood oxygen levels, stress data or other vital signs) using sensors included in the product.
- the location tracking to monitor the children position.
- heart-rate, electrocardiography and heart variability monitoring.
- blood oxygen saturation.
- stress monitoring.
- fatigue detection.

- 443 • respiratory rate.
- 444 • step counting, posture detection, fall detection.
- 445 • sleep monitoring.
- 446 • skin temperature, skin conductance.
- 447 • muscle activity.
- 448 • electroencephalography.
- 449 • vibrations detection, capturing heart and breathing sounds.

450 NOTE: The list above is provided as guidance only; it is not complete or future-proof.

451 4.3.2 Location-based functionalities (essential functionalities)

452 It includes activities regarding to the user's position. They may rely on radio technologies such as indoor radio (e.g.
453 Bluetooth[®], Wi-Fi[®]), outdoor radio (e.g. cellular, GPS), or light-based technologies (e.g. LED).

454 Examples of main location -based functionalities include:

- 455 • navigation which guides movement from one place to another;
- 456 • tracking which monitors user location;
- 457 • localization which determines the precise location;
- 458 • geofencing which creates virtual boundaries.

459 NOTE: The list above is provided as guidance only; it is not complete or future-proof.

460 4.3.3 Notification functionalities (essential functionalities)

461 It includes real-time alerts, messages, reports and reminders. They may rely on displays/LEDs, haptic actuators and
462 speakers or a companion mobile application.

463 Examples of notification functionalities include:

- 464 • reminders and recommendations: activity (break, relaxation), hydration, medication, bedtime;
- 465 • detections: stress, heart-rate, fall, heart-rate zone, fitness condition, trends;
- 466 • alarms: environmental hazard, fall, SOS, timers.

467 NOTE: The list above is provided as guidance only; it is not complete or future-proof.

468 4.3.4 Input commands from user or other connected devices (supporting 469 functionalities)

470 It includes interactions with the product using technologies such as touch screen, buttons, voice, gestures, biometrics
471 and other sensors, and commands from other connected devices.

472 4.3.5 Data logging and storage (supporting functionalities)

473 It includes logging of physiological data, environment data, behavioural data, name, health condition, trends and storage
474 of personal data such as age, weight, height, gender, and relies on product's memories.

4.3.6 General functionalities (supporting functionalities)

General functionalities are essential to allow the product to provide the main uses cases and the essential functionalities described in the previous clauses. General functionalities describe core, non-specialized functionalities of a product that support everyday interaction, usability, and system integration. These include functions such as device setup, account management, synchronization with smartphones or cloud services, battery status monitoring, user customization and updatability. The general functionalities are listed below:

- software update: The product checks for and installs firmware or software updates to ensure security, bug fixes and feature enhancements;
- factory reset mechanism: reset the product to the factory default state;
- registration: user have to register and log into a service account (e.g. to activate the product, sync data, or access cloud-based features/services);
- device pairing and setup: during initial setup, the product pairs with a connected device (e.g. smartphone) and walks the user through configuration steps like account login, preferences, and permissions;
- configuration: set, modify, configure and personalize the product's settings;
- deactivation: deactivate on the product certain services or the collection of certain data;
- data synchronization and backup: synchronize data with companion mobile application and/or cloud service and backup data on the cloud application;
- security functionalities: the functionalities that protect the data assets.

NOTE: The list above is provided as guidance only; it is not complete or future-proof.

4.3.7 Data assets

The essential and supporting functionalities might process the following data assets:

- health data;
- fitness data;
- input data from sensors;
- location data, including device location data;
- audio input data;
- video input data;
- network status data;
- access control policy data;
- confidential data;
- integrity relevant data;
- personal calendar data;
- personal contact data;
- personal notes data.

4.4 Product Architecture

This clause describes the two architectures for the products in the scope of the present document.

4.4.1 Wearable that have a health monitoring purpose architecture

The architecture of the health monitoring wearable is shown in Figure 1.

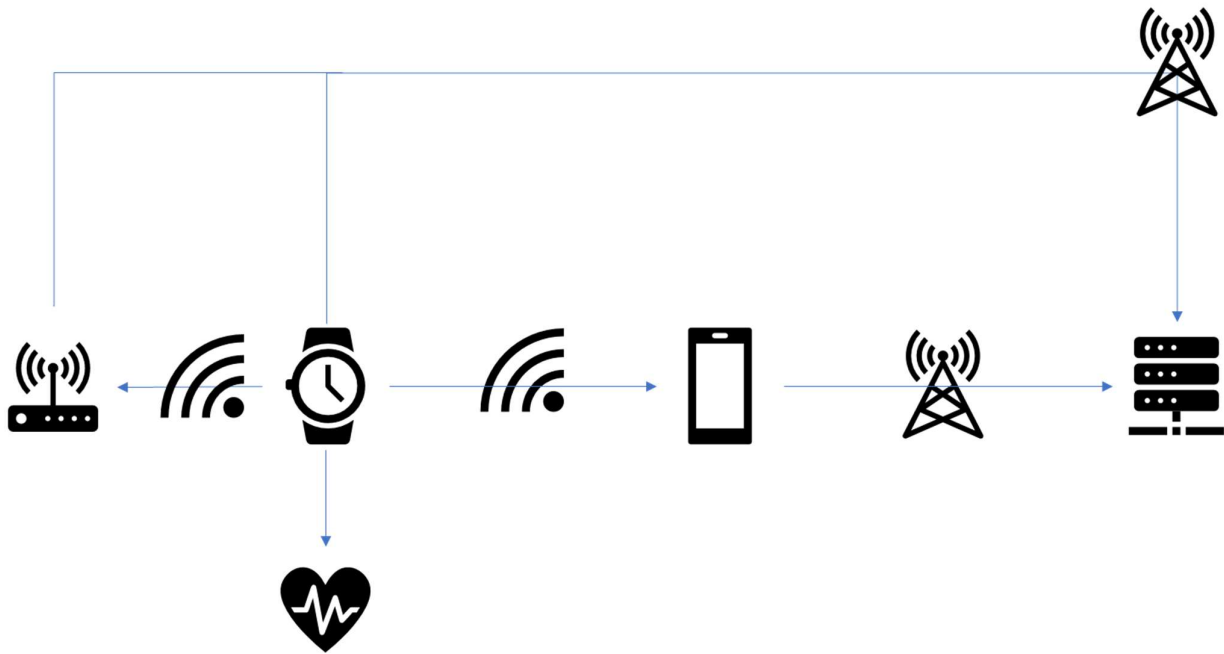


Figure 1: Health monitoring wearable architecture

- 1) The wearable device hosts several sensors, and through internal interfaces between the main processor and the sensors, it collects data about health and user activities.
- 2) The wearable device may be connected to a mobile application running typically on a mobile phone. The local radio link between them can be any type, typically Bluetooth® or Wi-Fi. Through this link the wearable device transfers to the mobile application the health data collected, the notifications, alerts, reminders and any other data needed to support its functionalities. If the wearable is a standalone device, or if it has the possibility to be directly connected to a cloud service (e.g. through an internet connection over Wi-Fi or cellular) it might not have an associated mobile application.

NOTE 1: The mobile application may be considered a remote data processing solution.

- 3) The mobile application associated to the wearable device may be connected to a remote service hosted in the cloud. The radio link may be Wi-Fi or mobile connection. Through this link the mobile application may transfer to the cloud service some processed data, activity report, health report and a backup of all the mobile application data, e.g. in order to be able to move the application on another mobile device if the user decide to change it. The remote service to which the mobile application is connected may also provide software updates for the wearable device that will be delivered through the link described in point 2.

NOTE 2: Under the CRA [i.1], the cloud service constitutes a remote data processing solution.

- 4) The wearable device in some cases is directly connected to a server hosting its cloud application (e.g. through a Wi-Fi or mobile connection). The radio link is most likely Wi-Fi or mobile connection. Through this link the wearable device transfers to the cloud application processed data, activity report, health report and a backup of all the wearable device data in order to be able to move them on another wearable device if the user decide to change it. The server to which the wearable device is connected can be also provide software updates.

NOTE 3: The cloud service may be considered a remote data processing solution.

- 5) The wearable device in some cases may be connected via a local connection to a gateway that perform then the remote connection to the cloud service.

Therefore, the architecture of wearable device consists of the following architectural components:

- The main product (hardware and software)
- The mobile application acting as remote data processing service (optional)
- The cloud service acting as remote data processing service (optional)
- The gateway (optional)

4.4.2 Wearable that are intended for the use by and for children architecture

The architecture of the health monitoring wearable is shown in Figure 2.

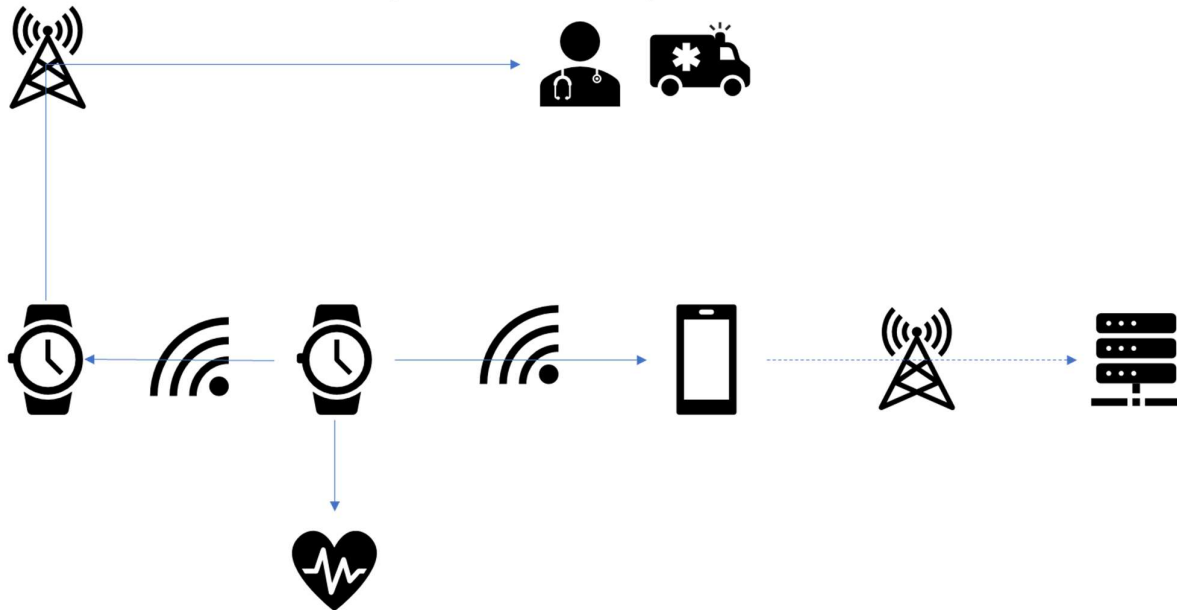


Figure 2: Health monitoring wearable architecture

- 1) The wearable device hosts several sensors, and through internal interfaces between the main processor and the sensors, it collects data about health and user activities.
- 2) The wearable device may be connected to a mobile application on a mobile phone. The radio link can be any type, typically Bluetooth® or Wi-Fi. Through this link the wearable device transfers to the mobile application the health data collected, the notifications, alerting, reminders and any other data needed to allow its functionalities. If the wearable is a standalone device or if it has the possibility to be directly connected to a remote cloud service (e.g. through an internet connection over Wi-Fi or cellular) it might not have an associated mobile application.

NOTE 1: Under the CRA [i.1], the mobile application may be considered a remote data processing solution.

- 3) The mobile application associated to the wearable device may be connected to a remote cloud service. The radio link may be Wi-Fi or cellular. Through this link the mobile application transfers to the cloud application processed data, activity report, health report and a backup of all the mobile application data, e.g. in order to be able to move the application on another mobile device if the user decide to change it. The remote service to which the mobile application is connected may also provide software updates for the wearable device that will be delivered through the link described in point 2.

NOTE 2: Under the CRA [i.1], the cloud application constitutes a remote data processing solution.

- 4) The wearable device in some cases is locally connected to another wearable device, usually controlled by the children's parents, which may perform a connection with remote emergency services infrastructure where needed (e.g. through an internet connection over Wi-Fi or cellular). Through this link the wearable device may transfer emergency requests and trigger the intervention of emergency staff, where necessary.

NOTE 3: Under the CRA [i.1], the emergency services infrastructure constitutes a remote data processing solution.

Therefore, the architecture of wearable device consists of the following architectural components:

- 1) The main product (hardware and software)
- 2) The mobile application acting as remote data processing service (optional)
- 3) The cloud application acting as remote data processing service (optional)
- 4) The emergency services infrastructure acting as remote data processing solution (optional)

4.5 Operational Environment

Common wearable devices placements include, but are not limited to, the wrist, finger, head, chest, clothing, shoes or belts. Wearables may operate continuously (24/7) or only be activated during specific activities (e.g. exercise). Their autonomy depends on battery life and recharge cycles and charging is handled via wired connectors, magnetic docks, or wireless power.

The physical environment of the wearable devices may include all typical consumer electronic physical environments, including homes, offices, wellness centres, but also outdoor spaces such as rural areas, city streets, sport stadiums. Wearable devices typically follow a user-centric trust model, assuming that the user will not attempt to compromise the device (e.g. alter the data) and the data is trustworthy before it leaves the device, however this may not hold in all user contexts, for example a user may have incentives to manipulate his/her location. Moreover, the presence of radio interfaces in wearables (e.g. NFC, BLE, Wi-Fi) may expose them to external threats including the risk of receiving malicious software and unauthorized commands, and even physical risks such as battery overheating.

For the physical operational environment, the following environments are addressed for the MPs.

- fully controlled physical operational environment - POE.FullyControlled
- partially controlled physical operational environment - POE.PartiallyControlled
- mobile operational environment - POE.Mobile
- controlled mobile operational environment - POE.MobileControlled

For the physical operational environment, the following environments are addressed for the mobile application RDPS:

- fully controlled physical operational environment - POE.FullyControlled
- partially controlled physical operational environment - POE.PartiallyControlled
- mobile operational environment - POE.Mobile

For the physical operation environment, the following environments are addressed for cloud service (RDPSs):

- fully controlled physical operational environment - POE.FullyControlled.

Logical environments include the connected systems around the main product that shape how it operates in its environment. The trusted boundary is affected by potential third party software that runs on the product, data links to the outside world using radio interfaces, and user permissions and access control.

For the logical operation environment, the following digital communication types are addressed for any architectural component of the product.

- public communication - COM.Public
- adjacent communication - COM.Adjacent

- local communication - COM.Local

4.6 Interfaces

The present document addresses the following interfaces of the product:

- human interface - IF.Human
- machine interface - IF.Machine
- logical interface - IF.Logical
- physical interface - IF.Physical

4.7 Users

4.7.1 End-Users

They acquire the product and connect it to the wearable manufacturer ecosystem using state-of-the-art security methods. They may have access to the information via the wearable device display, via the mobile application or another connected device. They may control who has access to their data and which third-party applications are installed on the wearable device. In the case of children, supervisors (such as parents or guardians) maintain control over these settings.

4.7.2 Manufacturers

Manufacturers deliver the product to market which may be coming together with a manufacturer mobile application and Remote Data Platform services. Guidelines are provided to the end-user for setting-up the product and connecting the product to the mobile phone or generally to the internet using state-of-the-art security methods. Manufacturers are pushing software updates to the wearable device and keep the software updated. Depending on the privacy agreements, terms of service and regulatory compliance the manufacturers may have access to the end-user data or not.

4.8 Use cases profiles

The present document addresses all use cases that can be constructed by the elements of clause 4.

In order to classify use cases and to define security profiles the following use case profiles are defined. Those definitions make use of impact classes of essential functionalities. The essential functionalities covered by the present document are provided in clause 4.4, their impact classes are provided in annex D.

4.8.1 Use case profile for basic impact essential functionalities

The use case profile for basic impact essential functionalities bundles all use cases addressed by the present document where the maximum (IMP.FH, IMP.AVAL.TIME) of a product's essential functionality falls under IMP.Basic.

Example of such use cases profile are:

TBD

4.8.2 Use case profile for medium impact essential functionalities

The use case profile for basic impact essential functionalities bundles all use cases addressed by the present document where the maximum (IMP.FH, IMP.AVAL.TIME) of a product's essential functionality falls under IMP.Medium.

Example of such use cases profile are:

TBD

4.8.3 Use case profile for high impact essential functionalities

The use case profile for high impact essential functionalities bundles all use cases addressed by the present document where the maximum (IMP.FH, IMP.AVAI.TIME) of a product's essential functionality falls under IMP.High.

Example use cases:

TBD.

4.9 Security Profiles

Editor's Note: Secure Profiles will be defined after the discussion of the Use case profiles

5 Requirements specifications

5.1 Product's technical requirements specifications

5.1.1 Known exploitable vulnerabilities

5.1.1.1 [NKEV] No known exploitable vulnerabilities

In accordance with [1] the product shall be tested prior to making available on the market to ensure that there are no insufficiently mitigated known exploitable vulnerabilities.

NOTE 1: The known exploitable vulnerabilities that occur after making the product available on the market are subject to the vulnerability handling in [1].

NOTE 2: Typically, products receive all necessary security updates during the first start up.

5.1.1.2 [NKEV-SUM] Secure software update mechanism

The product shall support software update mechanisms, that allow to update every part of the product's software, except for parts of the product's software, that are immutable due to technical reasons.

EXAMPLE: A mobile application acting as RDPS is installed on a device that supports updating the mobile application (e.g. via application distribution platform).

5.1.1.3 [NKEV-SUM-PROVIDE] Secure software update mechanism for core components

All architectural components of the product that include core software shall provide software update mechanisms, that allow to update every part of the architectural components' software, except for parts of the architectural components' software, that are immutable due to security.

NOTE: A mobile application typically does not need to provide an update mechanism.

5.1.1.4 [NKEV-UPD-AUTO] Automated security updates

The product shall support the automated update of its software.

5.1.1.5 [NKEV-UPD-NOTIF] Update notifications

The product shall support the automated notification of its users, when updates of its software are available.

5.1.2 Default configuration

5.1.2.1 [SDC-AUM-FH] Default configuration of authentication for functions whose use can cause harm

The SHPSF shall by default be configured to use authentication mechanisms that meet:

- the authentication mechanisms strengths specified in clause E.3.1; and
- the minimal authentication mechanisms' strength determined by table 3;

except for connection functions.

NOTE: The support of authentication for functions whose use can cause harm is addressed in [AUM-FH].

5.1.2.2 [SDC-UPD-AUTO] Default configuration of automated security updates

The product shall by default be configured to use automated software update mechanisms for its software.

NOTE: The support of automated security updates is addressed in [NKEV-UPD-AUTO].

5.1.2.3 [SDC-UPD-NOTIF] Default configuration of update notifications

The product shall by default be configured to receive automated notification and alert its users, when updates of the product's software are available.

NOTE: The support of update notification is addressed in [NKEV-UPD-NOTIF].

5.1.2.4 [SDC-FRM] Factory reset to restore the default state

The product shall provide a factory reset mechanism that allows a user to restore the default state, including the deletion of all user data, installed applications, and configurations deviating from the default state, except deviations due to security.

NOTE 1: It is also possible that the factory reset will delete the installed security updates if these are installed automatically or on request when the device is commissioned again.

NOTE 2: Annex II 8. d) of the CRA [i.1] contains legal obligations on how users of the product are informed about secure decommissioning.

5.1.3 Authentication and access control mechanisms

5.1.3.1 [ACM-FH] Access control for functions whose use can cause harm

The product shall use access control mechanisms to control entities' use of functions whose use can cause harm, where the applicability of this requirement is determined by table 2 except for connection functions.

Table 2: Assignment for access control mechanisms

			Impact class for function whose use can cause harm		
			IMP.FH.Basic	IMP.FH.Medium	IMP.FH.High
Attack Surface determined by COM, IF and POE of RDPS or MP that receives function trigger input	COM.Local via IF.Any	POE.FullyControlled	No	No	AC[1]
		POE.PartiallyControlled	No	AC[1]	AC[1]
		POE.Mobile	AC[1]	AC[1]	AC[1]
	COM.Local via IF.HumanPhysical	POE.FullyControlled	No	AC	AC
		POE.PartiallyControlled	AC	AC	AC
		POE.Mobile	AC	AC	AC

			Impact class for function whose use can cause harm		
			IMP.FH.Basic	IMP.FH.Medium	IMP.FH.High
	COM.Local via a non-IF.HumanPhysical	POE.Any	AC	AC	AC
	COM.Adjacent via IF.Any	POE.Any	AC	AC	AC
	COM.Public via IF.Any	POE.Any	AC	AC	AC

698

699 For protection measures that are labelled with [1] it is not required that the product uses access control mechanisms for
700 its following functions:

- 701
- factory reset function

702 5.1.3.2 [AUM-FH] Authentication for functions whose use can cause harm

703 The product shall support authentication mechanisms, to authenticate entities using functions whose use can cause harm
704 before generating function output, where

- 705
- the authentication mechanisms strengths are specified in clause E.2.1; and
 - the minimal required authentication strength is determined by table 3,

707 except for connection functions.

708

Table 3: Assignment for authentication mechanisms strengths

			Impact class for function whose use can cause harm		
			IMP.FH.Basic	IMP.FH.Medium	IMP.FH.High
Attack Surface determined by COM, IF and POE of RDPS or MP that receives function trigger input	COM.StrictLocal via IF.Any	POE.FullyControlled	No	No	AUTH.Medium[1]
		POE.PartiallyControlled	No	AUTH.Basic[1]	AUTH.Medium[1]
		POE.Mobile	AUTH.Basic[1]	AUTH.Medium[1]	AUTH.Enhanced[1]
	COM.Local via IF.HumanPhysical	POE.FullyControlled	No	AUTH.Basic	AUTH.Medium
		POE.PartiallyControlled	AUTH.Basic	AUTH.Medium	AUTH.Enhanced
		POE.Mobile	AUTH.Basic	AUTH.Medium	AUTH.Enhanced
	COM.Local via a non-IF.HumanPhysical	POE.Any	AUTH.Medium	AUTH.Medium	AUTH.Enhanced
	COM.Adjacent via IF.Any	POE.Any	AUTH.Medium	AUTH.Medium	AUTH.Enhanced
	COM.Public via IF.Any	POE.Any	AUTH.Medium	AUTH.Enhanced	AUTH.Enhanced

709

710 For protection measures that are labelled with [1] it is not required that the product uses authentication mechanisms for
711 its following functions:

- 712
- factory reset function

713 5.1.3.3 [AUTHZ-LP] Least privilege in authorization policies

714 The product shall use an authorization policy that only grants permissions that are necessary for the intended purpose.

715 EXAMPLE: A product with just one consumer grants that consumer all permissions.

5.1.3.4 [AUTHZ-R] Revocability of granted permissions

The product shall support the revocation of any permission granted by an authorized entity.

EXAMPLE: An administrative consumer can revoke permissions granted to another consumer.

5.1.4 Integrity protection

5.1.4.1 [INT-SWPCK] Software package verification

The product shall use software package verification mechanisms to verify the integrity and authenticity of software packages prior to installation where the software package verification mechanism's strength levels are specified in clause E.6.1 and where the minimal software package verification mechanism's strength is determined by table 4.

NOTE: The requirement addresses software packages that are updates and new software to be installed.

Table 4: Assignment of the software package verification mechanism's strength levels for the verification of software packages

		Highest IMP.INT of the SHPSF's integrity relevant functions		
		IMP.INT.Low	IMP.INT.Medium	IMP.INT.High
Attack Surface determined by the COM of RDPS or MP over which the software package is received	COM.Local	INT.SW.VER.Basic	INT.SW.VER.Basic	INT.SW.VER.Basic
	COM.Adjacent or COM.Public	INT.SW.VER.Normal	INT.SW.VER.Normal	INT.SW.VER.Enhanced

5.1.4.2 [INT-COM] Communication of integrity relevant data

The product shall use integrity protecting communication mechanisms to protect the integrity of communicated integrity relevant data, where the corresponding integrity protection measures strengths are specified in clause E.5.1 and the minimal required integrity protection measures' strength are determined by table 4.

Table 5: Assignment of protection mechanisms strength level for the integrity protection of outgoing data and for the integrity verification of incoming data

			Integrity relevant data impact class		
			IMP.INT.Basic	IMP.INT.Medium	IMP.INT.High
Attack Surface determined by COM, IF and POE of RDPS or MP that communicates integrity relevant data	COM.Local via IF.Machine	POE.Any	INT.COM.Basic INT.VER.Basic	INT.COM.Basic INT.VER.Basic	INT.COM.Basic INT.VER.Basic
	COM.Local via IF.Machine or IF.HumanLogical	POE.FullyControlled	INT.COM.Basic INT.VER.Basic	INT.COM.Basic INT.VER.Basic	INT.COM.Medium INT.VER.Medium
		POE.PartiallyControlled	INT.COM.Basic INT.VER.Basic	INT.COM.Medium INT.VER.Medium	INT.COM.Enhanced INT.VER.Enhanced
		POE.Uncontrolled	INT.COM.Medium INT.VER.Medium	INT.COM.Enhanced INT.VER.Enhanced	INT.COM.Enhanced INT.VER.Enhanced
	COM.Adjacent via IF.Any	POE.Any	INT.COM.Enhanced INT.VER.Enhanced	INT.COM.Enhanced INT.VER.Enhanced	INT.COM.Enhanced INT.VER.Enhanced
	COM.Public via IF.Any	POE.Any	INT.COM.Enhanced INT.VER.Enhanced	INT.COM.Enhanced INT.VER.Enhanced	INT.COM.Enhanced INT.VER.Enhanced

5.1.5 Confidentiality protection

5.1.5.1 [CONF-SSM] Confidentiality protecting persistent storage for confidential data

The product shall use confidentiality protecting secure storage mechanisms for persistently stored confidential data, where the mechanisms' strength are specified in clause E.4.1 and the minimal required mechanisms' strength are determined by table 6.

Table 6: Assignment for confidentiality protecting secure storage mechanisms

		Confidentiality impact class for persistently stored confidential data		
		IMP.CONF.Low	IMP.CONF.Medium	IMP.CONF.High
Attack Surface determined by POE of RDPS or MP that persistently stores confidential data	POE.FullyControlled	N/A	N/A	N/A
	POE.PartiallyControlled	N/A	CONF.SSM.Basic[1]	CONF.SSM.Normal
	POE.Mobile	CONF.SSM.Basic[1]	CONF.SSM.Normal	CONF.SSM.Enhanced

For protection measures labelled with [1], it is not required that the SHPSF uses confidentiality protecting persistent storage for confidential data for confidential data:

- which is persistently stored on non-removable storage

5.1.5.2 [CONF-COM] Communication of confidential data

The product shall use confidentiality protecting communication mechanisms to protect the confidentiality of communicated confidential data, where the corresponding confidentiality protection measures strengths are specified in clause E.5.1 and the minimal required confidentiality protection measures' strength are determined by table 7.

Table 7: Assignment of protection mechanisms strength level for the confidentiality of communicated data

			confidential data impact class		
			IMP.CONF.Low	IMP.CONF.Medium	IMP.CONF.High
Attack Surface determined by COM, IF and POE of RDPS or MP that communicates confidential data	COM.Local via IF.Machine or IF.HumanLogical	POE.FullyControlled	N/A	N/A	CONF.COM.Normal
		POE.PartiallyControlled	N/A	CONF.COM.Basic	CONF.COM.Normal
		POE.Uncontrolled	CONF.COM.Basic	CONF.COM.Normal	CONF.COM.Enhanced
	COM.Adjacent via IF.Any	POE.Any	CONF.COM.Enhanced	CONF.COM.Enhanced	CONF.COM.Enhanced
	COM.Public via IF.Any		CONF.COM.Enhanced	CONF.COM.Enhanced	CONF.COM.Enhanced

5.1.6 Data minimization

5.1.6.1 [DMIN-DJST] Documented justification of processed data

The product shall only process confidential data according to its intended purpose.

5.1.7 Availability protection

5.1.7.1 [AVAI-TIME-RECO-POW] Restoration after loss of power

The MP shall use a mechanism to resume connectivity and functionality in the case of a loss of power as soon as the power supply is restored.

5.1.7.2 [AVAI-TIME-NETW] Local operation

Where no network connectivity is necessary for a time sensitive function to operate, the product shall ensure the operability of this function in the case of a loss of network access.

5.1.7.3 [AVAI-TIME-RECO-NETW] Restoration after loss of network connection

The product shall use a mechanism to reconnect cleanly after a loss of network connection.

EXAMPLE: A product loses connection to the local network as the network is temporarily unavailable. After recognizing the restored network, the product reconnects after a randomized delay to reconnect cleanly.

NOTE: Reconnecting cleanly normally involves resuming connectivity to network in an expected, operational and stable state and in an orderly fashion taking the capability of the infrastructure into consideration.

5.1.7.4 [AVAI-TIME-OUTA-NOT] Notify non-availability

Where at least one time sensitive function with IMP.AVAI.TIME.Medium or higher is provided by the product, the product shall use a mechanism to warn the user before or at least during a IMP.AVAI.TIME.Medium or higher function becomes unavailable due to CPU, memory, power or network limitations.

EXAMPLE 1: A cloud RDPS recognizes a non-availability of its MP and sends a notification to the user.

EXAMPLE 2: A product with a network-dependent IMP.AVAI.TIME.High function recognizes a low bandwidth and sends a notification to the user.

5.1.7.5 [AVAI-TIME-PREV-NOT] Notify upcoming limitation

Where at least one time sensitive function with IMP.AVAI.TIME.High is provided by the product, the product shall use a mechanism to notify the user when the product recognizes upcoming resource limitations.

EXAMPLE: A battery powered product recognizes low battery and sends a notification to the user.

5.1.7.6 [AVAI-TIME-PREV-PRIO] Network prioritization

Where at least one time sensitive function with IMP.AVAI.TIME.Medium or higher with the need of network connectivity for operation is provided by the product, the product shall use a mechanism to prioritize the execution of these functions in the case of a network resource conflict.

5.1.7.7 [AVAI-TIME-PREV-PRIO] Resource prioritization

Where at least one time sensitive function with IMP.AVAI.TIME.Medium or higher is provided by the product, the product shall use a mechanism to prioritize the execution of these functions in the case of a CPU, memory or power resource conflict.

EXAMPLE: The product uses the following prioritization in case of resource conflict (high to low priority):

- 1) Time sensitive availability relevant functions
- 2) Authenticated user commands
- 3) Background tasks (e.g. logging, updates)

792 NOTE: At least the following resources can cause a processing resource conflict: CPU, memory, power.

793 5.1.7.8 [AVAI-TIME-IMP-AMP] Amplification control

794 TBD

795 5.1.7.9 [AVAI-TIME-DOS-RATE] Incoming rate limiting

796 TBD

797 5.1.7.10 [AVAI-UPD-SCHEDULE] Scheduling of updates

798 Where at least one time sensitive function with IMP.AVAI.TIME.Medium or higher is provided by the product, the
799 product shall support the scheduling of the application of updates that can impact the availability of these functions with
800 IMP.AVAI.TIME.Medium or higher.

801 5.1.8 Impact minimization

802 TBD

803 5.1.9 Limit attack surface

804 5.1.9.1 [LAS-INVAL] Validation of external data input

805 The product shall use input validation mechanisms for all external data input.

806 EXAMPLE: If external data input via a specific interface is expected to be an email address, the product rejects
807 external data input that has not the format of an email address.

808 NOTE: The specific pattern to accept external data input depends amongst others on the manner the external data
809 input is intended to be processed. This means that an acceptance pattern for broad purposes (such as
810 administration via a "Secure Shell") is typically less specific than an acceptance pattern for a specific
811 purpose (such as a measurement value of a specific format to be stored).

812 5.1.9.2 [LAS-INSAN] Sanitization of external data input

813 The product shall use input sanitization mechanisms before using external data input as function input, where the
814 validation of external data input cannot prevent potential incidents triggered by the external data input.

815 EXAMPLE: If external data input is amongst others intended to be stored via a database service, escape
816 characters and other database service specific commands are removed from the external data input,
817 before it is processed by the database service.

818 5.1.9.3 [LAS-PHY-INF] Only necessary physical interfaces

819 A hardware MP shall only provide physical interfaces, that are necessary for the product's intended purpose.

820 5.1.9.4 [LAS-LOGIC-INF] Only necessary logical interfaces active by default

821 The product shall by default only use logical interfaces, that are necessary for its intended purpose.

822 5.1.9.5 [LAS-APP] Only necessary apps by default

823 The product shall by default only use application softwares, that are necessary for its intended purpose.

824 5.1.10 Logging and monitoring mechanisms

825 TBD

5.1.11 Deletion mechanisms

TBD

5.1.12 Other product's technical requirements specifications

This subclause is intended to address cybersecurity risks that are identified but not covered by the ECRs of CRA ANNEX I Part I (2).

TBD

5.2 Requirements specifications for vulnerability handling activities related to the product

The requirements specified in prEN 40000-1-3 [1] shall be fulfilled for the product.

6 Assessing for compliance with requirements

Editor's Note: The assessment of the requirements defined in the present document will be derived by the assessment defined in the EN 304 631 / EN 304 632 / EN 304 633. They will be included in the present document when the discussion on them will be completed

Annex A (informative): Relationship between the present document and the requirements of EU Regulation 2024/2847

The present document has been prepared under the Commission's Standardisation request M/606 - C(2025)618 [i.3] to provide one voluntary means of conforming to the requirements of Regulation (EU) No 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

Table A.1: Relationship between the present document and the requirements of Regulation (EU) 2024/2847 [i.1]

Editor's Note: The relationship between the present document and the and the requirements of EU Regulation 2024/2847 has to be finalized by the group. They will be included in the present document when the discussion on them will be completed.

Annex B (informative): Guidance for the application of the present document

The following approach can be used (e.g. by manufacturers)

- to develop wearables that are compliant the present document; or
- to analyse the compliance of a wearable to the present document.

The approach is constructed such that it uses parts of an assessment of cybersecurity risks and can be integrated into the management of cybersecurity risks.

- Step 1 - check if the wearable is in scope of the present document provided in clause 1 by:
 - verifying that the wearable is a product as specified in the present document and within the "technical description" of the "category of product" number "17." by Regulation (EU) 2025/2392 [i.2]; and
 - identifying the product context by:
 - Identify the product's intended use; and
 - identifying the product's architectural components; and
 - identifying all data processed by the product (data assets); and
 - identifying all functions provided by the product (function assets); and
 - identifying the architectural components' operational environments; and
 - identifying the architectural components' interfaces and communication types; and
 - verifying that the product is covered within the product context described in clause 4 by:
 - Verify that the intended use of the product is covered within the product's intended purpose and foreseeable use in clause 4.1; and
 - verifying that the architectural components of the product are covered within the product architecture described in clause 4.5; and
 - verifying that the data processed by the product and the functions provided by the product are covered within clause 4.5; and
 - verifying that the architectural components' operational environments are covered within clause 4.6; and
 - verifying that the architectural components' interfaces and communication types are covered within clause 4.7.

NOTE 1: The identification of the items mentioned above can be reused for assessing the compliance of the product with the requirements in clause 5.

NOTE 2: If a product is a SHPSF as specified by Regulation (EU) 2025/2392 [i.1] but is not covered within the product context described in clause 4, it is assumed that the product is not or not completely covered by the present document. In such cases informing ETSI Technical Committee Cyber Working Group for EUSR (CYBER-EUSR) via the Committee Support Staff might help to address those products in potential revisions of the present document.

- Step 2 - identify information to determine risk factors by:
 - identifying for each function provided by the product:
 - its impact classes according to clause D.3; and
 - the architectural components that perform the function; and

- 896 ▪ the communication types and the interfaces that can receive corresponding function trigger input;
897 and
- 898 - identifying for each data processed by the product:
 - 899 ▪ its impact classes according to clause D.2
 - 900 ▪ the architectural components that persistently store the data; and
 - 901 ▪ the architectural components that can communicate the data; and
 - 902 ▪ the communication types and the interfaces over which the data is communicated.

903 NOTE 3: If data processed by the product or functions provided by the product are not covered within clause 4.1,
904 clause C.1 can be used to identify impact classes for function and data assets that are outside the scope of
905 the present document.

- 906 • Step 3 - identify concrete requirements for and specific security measures/mitigations of the product that
907 satisfy those requirements by:
 - 908 - for each requirement in clause 5:
 - 909 ▪ identifying the requirements applicability by evaluating the requirement's potential preconditions
910 and exceptions based on the product's properties; and
 - 911 ▪ (for requirements that include assignment tables) identifying the required protection mechanisms'
912 strengths (specified in annex E) by evaluating the requirement's assignment table based on the
913 product's properties determining the attack surface and impact parameters; and
 - 914 ▪ identifying the specific security measures/mitigations that satisfy the requirement.

915 NOTE 4: An assignment table can yield multiple mechanisms' strengths from different circumstances, which all
916 have to be satisfied.

917 EXAMPLE: Authentication requirements prior to changes of a product's configuration are different whether the
918 changes can be made via a web GUI, accessible from adjacent or public networks, a GUI,
919 accessible from the product's touchscreen, or a console, accessible be connecting to a serial port.
920 All of this case can be simultaneously present on the same product.

- 921 • Step 4 - assess the compliance of the product with the requirements in clause 5 by:
 - 922 - for each requirement in clause 5, performing the corresponding assessment for compliance described in
923 clause 6 (the functional sufficiency assessments for different protection measures strengths are specified
924 in annex E) by:
 - 925 ▪ preparing the assessment for the product; and
 - 926 ▪ performing the assessment activities for the product; and
 - 927 ▪ assigning an assessment verdict for the product; and
 - 928 ▪ generating the supporting evidences for the assessment.

929 The figure B.1 provides a graphical representation of the guidance for the application of the present document.

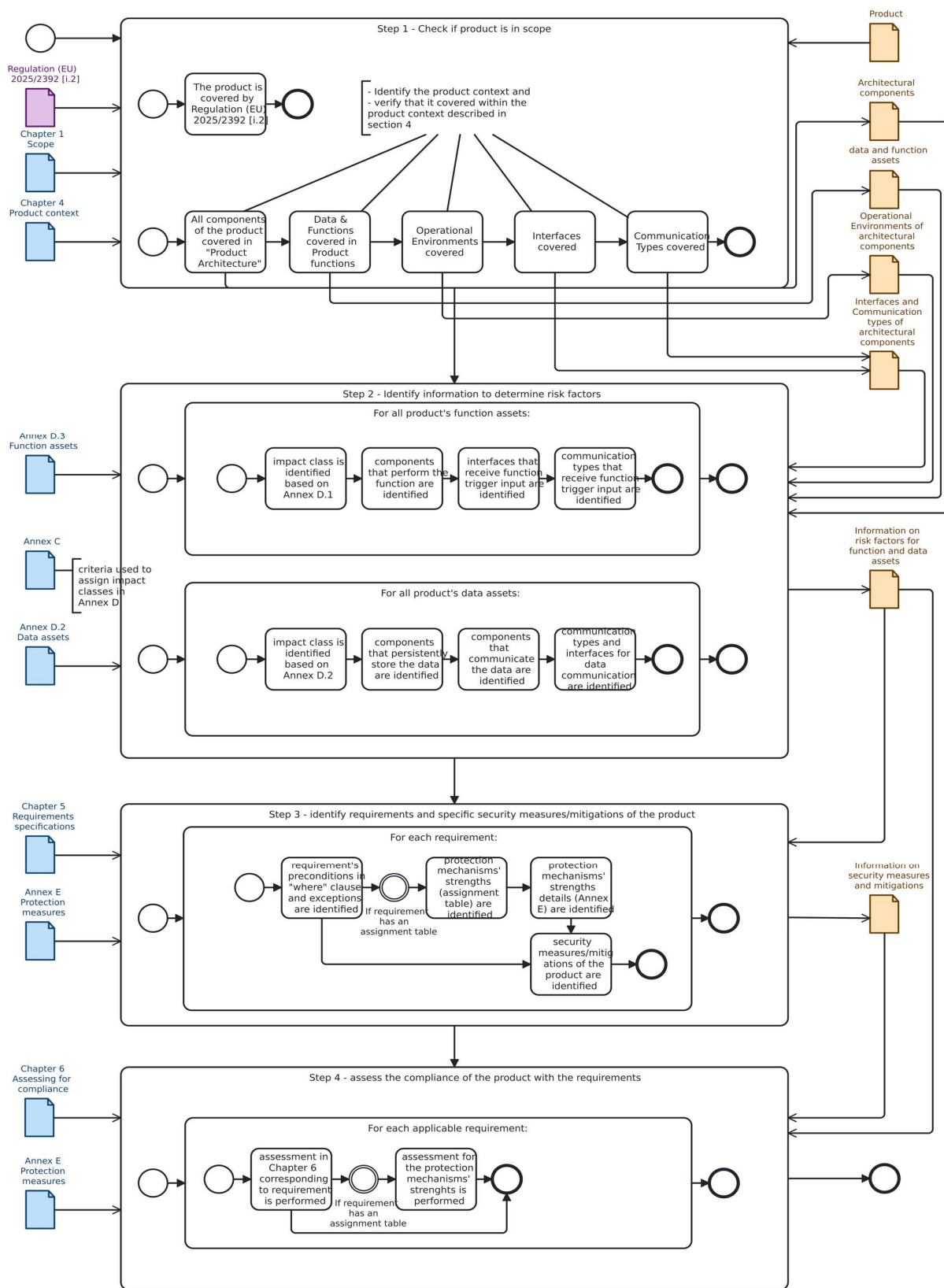


Figure B.1: Graphical representation for the application of the present document

Annex C (informative): Information on the methodology for the assessment of cybersecurity risks used to develop the present document

This informative annex is intended to provide information on the methodology for the assessment of cybersecurity risks used to develop the present document.

C.1 Guidance for determining impact classes

C.1.1 General

The present document uses the following criteria to determine the impact classes of different specific product's assets provided in annex D.

C.1.2 Confidential data

confidentiality impact class basic (IMP.CONF.Low):

The disclosure may lead to:

- inconvenient consequences on the user(s); or
- additional or increased attack opportunities over a short time and limited to communication types not higher than local on the product.

confidentiality impact class medium (IMP.CONF.Medium):

The disclosure may lead to:

- serious impact on the user(s);
- additional or increased attack opportunities over a short time on the product or
- additional or increased attack opportunities over a prolonged time limited to non-essential functionalities on the product.

confidentiality impact class high (IMP.CONF.High):

The disclosure may lead to:

- significant or even irreversible impact on the user(s) (e.g. personal or financial harm);
- additional or increased attack opportunities over a prolonged time on the product; or
- additional or increased attack opportunities over a short time on a significant number of products.

C.1.3 loss sensitive data

loss sensitive availability impact class low (IMP.AVALOSS.Low):

The loss may lead to:

- inconvenient consequences on the user(s); or
- non-availability of non-essential functionalities on the product for a short time.

loss sensitive availability impact class medium (IMP.AVALOSS.Medium):

The loss may lead to:

- serious impact on the user(s); or
- non-availability of essential functionalities of the product over a short time; or
- non-availability of essential functionalities on the product for a prolonged time.

loss sensitive availability impact class high (IMP.AVAL.LOSS.High):

The loss may lead to:

- significant or even irreversible impact on the user(s) (e.g. personal or financial harm);
- non-availability of essential functionalities of the product for a prolonged time; or
- permanent non-availability of non-essential functionalities of the product.

C.1.4 time sensitive data and time sensitive function

time sensitive availability impact class low (IMP.AVAL.TIME.Low):

The delay of availability may lead to:

- non-availability of non-essential functionalities on the product for a short time.

time sensitive availability impact class medium (IMP.AVAL.TIME.Medium):

The delay of availability may lead to:

- non-availability of essential functionalities on the product for a short time; or
- non-availability of non-essential functionalities on the product for a prolonged time.

time sensitive availability impact class high (IMP.AVAL.TIME.High):

The delay of availability may lead to:

- non-availability of essential functionalities of the product for a prolonged time; or
- permanent non-availability of non-essential functionalities of the product.

C.1.5 integrity relevant data and integrity relevant function

integrity impact class low (IMP.INT.Low):

The tampering may lead to:

- inconvenient consequences on the user(s);
- additional or increased attack opportunities for a short time and limited to communication types not higher than local on the product; or
- non-availability of non-essential functionalities on the product for a short time.

integrity impact class medium (IMP.INT.Medium):

The tampering may lead to:

- serious impact on the user(s);
- additional or increased attack opportunities over a short time on the product; or
- a limited number of other products;

- 998 • additional or increased attack opportunities over a prolonged time limited to non-essential functionalities on
999 the product; or
- 1000 • non-availability of essential functionalities on the product for a short time; or
- 1001 • non-availability of non-essential functionalities on the product for a prolonged time.
- 1002 **integrity impact class high (IMP.INT.High):**
- 1003 The tampering may lead to:
- 1004 • significant or even irreversible impact on the user(s) (e.g. personal or financial harm);
- 1005 • additional or increased attack opportunities for a prolonged time on the SHGPVA or a limited number of other
1006 products;
- 1007 • additional or increased attack opportunities for a short time on a significant number of other products;
- 1008 • non-availability of key-functionalities of the SHGPVA for a prolonged time; or
- 1009 • permanent non-availability of non-key-functionalities of the SHGPVA.
- 1010

Annex D (normative): Relationship between specific data and functions assets covered by the present document to impact classes for generic asset categories

This normative annex is intended to provide the relationship between specific product data/functions and generic product assets. This approach allows to use the terms for generic product assets within the requirements while providing a clear relationship to the specific product data/functions.

D.1 Identifier

The following identifier for impact classes apply:

IMP: impact class

IMP.Low: impact class low

IMP.Medium: impact class medium

IMP.High: impact class high

IMP.CONF: confidentiality impact class

IMP.CONF.Low: confidentiality impact class low

IMP.CONF.Medium: confidentiality impact class medium

IMP.CONF.High: confidentiality impact class high

IMP.INT: integrity impact class

IMP.INT.Low: integrity impact class low

IMP.INT.Medium: integrity impact class medium

IMP.INT.High: integrity impact class high

IMP.AVAL.TIME: time sensitive availability impact class

IMP.AVAL.TIME.Low: time sensitive availability impact class low

IMP.AVAL.TIME.Medium: time sensitive availability impact class medium

IMP.AVAL.TIME.High: time sensitive availability impact class high

IMP.AVAL.LOSS: loss sensitive availability impact class

IMP.AVAL.LOSS.Low: loss sensitive availability impact class low

IMP.AVAL.LOSS.Medium: loss sensitive availability impact class medium

IMP.AVAL.LOSS.High: loss sensitive availability impact class high

IMP.FH: impact class for function, whose use can cause harm

IMP.FH.Low: function, whose use can cause harm impact class low

IMP.FH.Medium: function, whose use can cause harm impact class medium

IMP.FH.High: function, whose use can cause harm impact class high

IMP.FH.SP: function, whose use can impact the safety or privacy of human entities impact class

- 1045 **IMP.FH.SP.Low:** function, whose use can impact the safety or privacy of human entities impact class low
- 1046 **IMP.FH.SP.Medium:** function, whose use can impact the safety or privacy of human entities impact class medium
- 1047 **IMP.FH.SP.High:** function, whose use can impact the safety or privacy of human entities impact class high
- 1048 **IMP.FH.DSN:** function, whose use can impact the availability of other devices, services or networks impact class
- 1049 **IMP.FH.DSN.Low:** function, whose use can impact the availability of other devices, services or networks impact class
- 1050 low
- 1051 **IMP.FH.DSN.Medium:** function, whose use can impact the availability of other devices, services or networks impact
- 1052 class medium
- 1053 **IMP.FH.DSN.High:** function, whose use can impact the availability of other devices, services or networks impact class
- 1054 high
- 1055 **IMP.FH.CCON:** function, which can communicate confidential data impact class
- 1056 **IMP.FH.CCON.Low:** function, which can communicate confidential data impact class low
- 1057 **IMP.FH.CCON.Medium:** function, which can communicate confidential data impact class medium
- 1058 **IMP.FH.CCON.High:** function, which can communicate confidential data impact class high
- 1059 **IMP.FH.MINT:** function, which can modify integrity relevant data impact class
- 1060 **IMP.FH.MINT.Low:** function, which can modify integrity relevant data impact class low
- 1061 **IMP.FH.MINT.Medium:** function, which can modify integrity relevant data impact class medium
- 1062 **IMP.FH.MINT.High:** function, which can modify integrity relevant data impact class high

D.2 Data assets

Table D.1: Mapping of specific data assets to impact classes

Specific data asset	Impact class for data asset categories			
	Impact class for confidential product data	Impact class for integrity relevant product data	Impact class for time critical availability relevant product data	Impact class for loss critical availability relevant product data
health data;	CONF.High	INT.High	IMP.AVAI.TIME.Medium	IMP.AVAI.LOSS.Medium
fitness data;	CONF.Medium	INT.Medium	IMP.AVAI.TIME.Low	IMP.AVAI.LOSS.Medium
input data from sensors;	CONF.Medium	INT.Medium	IMP.AVAI.TIME.Medium	IMP.AVAI.LOSS.Medium
location data, including device location data;	CONF.Medium	INT.Medium	IMP.AVAI.TIME.Low	IMP.AVAI.LOSS.Low
audio input data;	CONF.Low	INT.Low	IMP.AVAI.TIME.Low	IMP.AVAI.LOSS.Low
video input data;	CONF.Low	INT.Low	IMP.AVAI.TIME.Low	IMP.AVAI.LOSS.Low
network status data;	CONF.Low	INT.Low	IMP.AVAI.TIME.Low	IMP.AVAI.LOSS.Low
access control policy data;	CONF.High	INT.High	IMP.AVAI.TIME.High	IMP.AVAI.LOSS.High
confidential data;	CONF.Medium	INT.Medium	IMP.AVAI.TIME.Medium	IMP.AVAI.LOSS.Medium
integrity relevant data;	CONF.Medium	INT.Medium	IMP.AVAI.TIME.Medium	IMP.AVAI.LOSS.Medium
personal calendar data;	CONF.Medium	INT.Medium	IMP.AVAI.TIME.Medium	IMP.AVAI.LOSS.Medium
personal contact data;	CONF.High	INT.High	IMP.AVAI.TIME.High	IMP.AVAI.LOSS.High
personal notes data;	CONF.Medium	INT.Medium	IMP.AVAI.TIME.Medium	IMP.AVAI.LOSS.Medium

D.3 Function assets

Table D.2: Mapping of specific function assets to impact classes for generic function asset categories

Specific function asset	Impact class for function asset categories		
	Impact class for integrity relevant function	Impact class for time sensitive function	Impact class for function, whose use can cause harm
Health monitoring functionalities	IMP.INT.High	IMP.AVAI.TIME.High	IMP.FH.Medium
Location-based functionalities	IMP.INT.Low	IMP.AVAI.TIME.Medium	IMP.FH.Medium
Notification functionalities	IMP.INT.Medium	IMP.AVAI.TIME.Medium	IMP.FH.Medium
Input commands from user or other connected devices	IMP.INT.Low	IMP.AVAI.TIME.Low	No
Data logging and storage	IMP.INT.Medium	IMP.AVAI.TIME.High	No
General functionalities	IMP.INT.Medium	IMP.AVAI.TIME.Medium	IMP.FH.Medium

D.3.1 Functions whose use can cause harm

The contents of the column *impact class for function, whose use can cause harm* of table D.3 are split into details in table D.4.

Table D.4: Mapping of specific function assets to impact classes for different aspects of function, whose use can cause harm

Specific function asset	Impact class for function asset categories				
	Impact class for function, whose use can impact the safety or privacy of human entities	Impact class for function, whose use can impact the availability of other devices, services or networks	Impact class for function, which can communicate confidential data	Impact class for function, which can modify integrity relevant data	Impact class for function, whose use can cause harm
Health monitoring functionalities	IMP.FH.SP.High	no	no	no	IMP.FH.Medium
Location-based functionalities	IMP.FH.SP.Medium	no	no	no	IMP.FH.Medium
Notification functionalities	IMP.FH.SP.Medium	no	no	np	IMP.FH.Low
General functionalities	IMP.FH.SP.Medium	no	IMP.FH.SP.Medium	IMP.FH.SP.Medium	no

Annex E (normative): Protection measures

This normative annex is intended to provide descriptions of specific protection measures (mitigation) that satisfy certain requirements (e.g. a description of authentication mechanisms that satisfy AUM.Basic/Medium/High) as well as functional tests to assess their correct implementation

E.1 Identifier

The following identifier apply here and in the assignment tables in clause 5:

N/A: not applicable

AUTH.Basic: authentication strength level basic

AUTH.Normal: authentication strength level normal

AUTH.Enhanced: authentication strength level enhanced

AUTH.Strong: authentication strength level strong

CONF.COM.Basic: communication of confidential data protection strength level basic

CONF.COM.Normal: communication of confidential data protection strength level normal

CONF.COM.Enhanced: communication of confidential data protection strength level enhanced

CONF.COM.Strong: communication of confidential data protection strength level strong

INT.COM.Basic: communication of integrity relevant data protection strength level basic

INT.COM.Normal: communication of integrity relevant data protection strength level normal

INT.COM.Enhanced: communication of integrity relevant data protection strength level enhanced

INT.COM.Strong: communication of integrity relevant data protection strength level strong

CONF.SSM.Basic: confidential persistent storage strength level basic

CONF.SSM.Normal: confidential persistent storage strength level normal

CONF.SSM.Enhanced: confidential persistent storage strength level enhanced

CONF.SSM.Strong: confidential persistent storage strength level strong

SAN.Normal: input sanitization of input strength level normal

SAN.Strong: input sanitization of input strength level strong

AUT.VER.Enhanced: authenticity verification strength level enhanced

AUT.VER.Strong: authenticity verification strength level strong

INT.SW.VER.Basic: software package integrity verification strength level basic

INT.SW.VER.Normal: software package integrity verification strength level normal

INT.SW.VER.Enhanced: software package integrity verification strength level enhanced

INT.SW.VER.Strong: software package integrity verification strength level strong

INT.VER.Basic: integrity verification strength level basic

INT.VER.Normal: integrity verification strength level normal

1112 **INT.VER.Enhanced:** integrity verification strength level enhanced

1113 **INT.VER.Strong:** integrity verification strength level strong

1114 E.2 access control mechanism's strength

1115 E.3 authentication mechanism strength

1116 E.3.1 AUM-FH Authentication for functions whose use can cause 1117 harm

1118 E.3.1.1 General

1119 The present document specifies the strength of authentication mechanisms by their resistance against certain attack
1120 types. Those attack types are constructed such that mechanisms of higher strength protect against all attack types
1121 required for lower strengths.

1122 E.3.1.2 Authentication strength level basic

1123 The authentication strength level basic shall protect against the following attack types:

1124 **limited presentation attack:** Opportunistic presentation attacks on authentication mechanisms based on authentication
1125 factors of the type inherence, using authentication factors of another entity

1126 **limited brute force attack:** Opportunistic guessing attacks on authentication mechanisms based on authentication
1127 factors of the type knowledge, by guessing manually without the use of technical aids.

1128 E.3.1.3 Authentication strength level normal

1129 The authentication strength level normal shall protect against the following attack types:

1130 **automated brute force attack:** Brute force attacks on authentication mechanisms based on authentication factors of the
1131 type knowledge, by systematic try out with technical.

1132 **presentation attack:** Presentation attacks on authentication mechanisms based on authentication factors of the type
1133 inherence, using medium effort methods like e.g. photos, cut out masks, audio replays, video replays, AI generated
1134 voices

1135 **automated security token spoofing attack:** Security token spoofing attacks on authentication mechanisms based on
1136 authentication factors of the type possession, by using authentication factors sourced from other uses or self-created,
1137 without using any specific knowledge of the targeted authentication mechanisms.

1138 **replay attack:** An attacker intercepts valid data transmission and retransmits them to mimic the original communication
1139 partner for accepting an authentication based on the authentication factors of the type knowledge or possession (e.g. a
1140 session token).

1141 **person in the middle attack:** An attacker secretly intercepts and alters the authentication between two parties who
1142 believe they are communicating directly with each other based on the authentication factors of the type knowledge or
1143 possession (e.g. a session token).

1144 E.3.1.4 Authentication strength level enhanced

1145 The authentication strength level enhanced shall protect against the following attack types:

1146 **targeted presentation attack:** Presentation attacks on authentication mechanisms based on authentication factors of the
1147 type inherence, using enhanced effort methods like e.g. (partial) silicone masks, layered prints.

targeted brute force attack: Brute force attacks on authentication mechanisms based on authentication factors of the type knowledge, by systematic try out with technical aids, making use of target specific information.

targeted security token spoofing attack: Security token spoofing attacks on authentication mechanisms based on authentication factors of the type possession, by using authentication factors sourced from devices of the same type as the product or self-created, using specific knowledge of the targeted authentication mechanisms and the product.

replay attack: An attacker intercepts valid data transmission and retransmits them to mimic the original communication partner for accepting an authentication based on the authentication factors of the type knowledge or possession (e.g. a session token).

person in the middle attack: An attacker secretly intercepts and alters the authentication between two parties who believe they are communicating directly with each other based on the authentication factors of the type knowledge or possession (e.g. a session token).

E.3.1.5 Authentication strength level strong

The authentication strength level strong shall protect against the following attack types:

elaborate presentation attack: Presentation attacks on authentication mechanisms based on authentication factors of the type inheritance", using high effort methods like e.g. highly realistic silicone or latex masks, limb replicas, trained deep fakes.

elaborate brute force attack: Brute force attacks on authentication mechanisms based on authentication factors of the type knowledge, by systematic try out with technical aids, making use of target specific information, and unrestricted duration.

elaborate security token spoofing attack: Security token spoofing attacks on authentication mechanisms based on authentication factors of the type possession, by using authentication factors created or sourced from devices of the same type as the product and modified, specifically for the targeted authentication mechanisms.

replay attack: An attacker intercepts valid data transmission and retransmits them to mimic the original communication partner for accepting an authentication based on the authentication factors of the type knowledge or possession (e.g. a session token).

person in the middle attack: An attacker secretly intercepts and alters the authentication between two parties who believe they are communicating directly with each other based on the authentication factors of the type knowledge or possession (e.g. a session token).

E.3.2 Assessment for authentication mechanism strength

E.3.2.1 Assessment criteria regarding the protection against limited presentation attacks

Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a basic level of protection and use authentication factors of the type inheritance against limited presentation attacks.

Assessment preparation:

- the product shall be set up in default configuration;
- a genuine enrolled biometric template in the corresponding authentication mechanism with credential for authentication shall be created;
- at least one interface, where the authentication mechanism is reachable shall be documented.

1187 **Assessment activities:**

- 1188 • authentication at the created genuine enrolled biometric template shall be attempted using the correct genuine
1189 enrolled biometric template identifier, if present, and authentication factors, not belonging to the person who
1190 set up the account, for at least five times or ten minutes at highest archivable query frequency;
- 1191 • the outcome and used authentication factor of each attempt shall be recorded.

1192 **Assignment of verdict:**

1193 The verdict PASS shall be assigned if the authentication mechanism rejects all attempts.

1194 The verdict FAIL shall be assigned otherwise.

1195 **Supporting Evidence:**

- 1196 • description of the performed test;
- 1197 • all test records of the performed test.

1198 **E.3.2.2 Assessment criteria regarding the protection against targeted**
1199 **presentation attacks**

1200 **Assessment objective:**

1201 The assessment covers functional testing of authentication mechanisms that provide an enhanced level of protection and
1202 use authentication factors of the type inherence against targeted presentation attacks.

1203 **Assessment preparation:**

- 1204 • the product shall be set up in default configuration
- 1205 • a genuine enrolled biometric template in the corresponding authentication mechanism with credential for
1206 authentication shall be created;
- 1207 • at least one interface, where the authentication mechanism is reachable shall be documented;
- 1208 • authentication factors shall be fabricated using common materials and tools as well as readily available source
1209 materials. The fabrication process shall not be longer than *one workday* per authentication factor.

1210 **Assessment activities:**

- 1211 • authentication at the created genuine enrolled biometric template shall be attempted using the correct genuine
1212 enrolled biometric template identifier, if present, and at least two fabricated authentication factors tried at least
1213 five times with slightly different parameters each;
- 1214 • the outcome and used authentication factor of each attempt shall be recorded.

1215 **Assignment of verdict:**

1216 The verdict PASS shall be assigned if the authentication mechanism rejects all attempts.

1217 The verdict FAIL shall be assigned otherwise.

1218 **Supporting Evidence:**

- 1219 • description of the performed test;
- 1220 • all test records of the performed test.

E.3.2.3 Assessment criteria regarding the protection against elaborate presentation attacks

Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a high level of protection and use authentication factors of the type inherence against elaborate presentation attacks.

Assessment preparation:

- the product shall be set up in default configuration;
- a genuine enrolled biometric template in the corresponding authentication mechanism with credential for authentication shall be created;
- at least one interface, where the authentication mechanism is reachable shall be documented;
- authentication factors shall be fabricated using specialized materials and tools as well as cumbersome extracted source materials. The duration of the fabrication process per authentication factor is not restricted.

Assessment activities:

- authentication at the created genuine enrolled biometric template shall be attempted using the correct genuine enrolled biometric template identifier, if present, and at least two fabricated authentication factors tried at least five times with slightly different parameters each;
- the outcome and used authentication factor of each attempt shall be recorded.

Assignment of verdict:

The verdict PASS shall be assigned if the authentication mechanism rejects all attempts.

The verdict FAIL shall be assigned otherwise.

Supporting Evidence:

- description of the performed test;
- all test records of the performed test.

E.3.2.4 Assessment criteria regarding the protection against limited brute force attacks

Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a basic level of protection and use authentication factors of the type knowledge against limited brute force attacks.

Assessment preparation:

- the product shall be set up in default configuration;
- at least one interface, where the authentication mechanism is reachable shall be documented;
- the security insurance time (T_{SI}) for this assessment is 10 minutes (600 s).

Assessment activities:

- the minimal recommended complexity of passwords accepted by the mechanism ($C_{PW,min}$) shall be determined; e.g. $C_{PW,min} = (10)^6$ for a 6-digit PIN or $C_{PW,min} = \frac{9!}{(9-5)!}$ for a pattern of 5 nonrecurring nodes in a field of 9 notes;

- 1257 • the maximum sustained login attempt frequency ($f_{LA,max}$) shall be determined; e.g. $f_{LA,max} = \frac{5}{5 \cdot 3s + 3600s}$ for 3
- 1258 seconds per login attempt + a one-hour waiting period after 5 failed login attempts;
- 1259 • the probability of guessing a completely random password of the minimal recommended complexity (p_{GRP})
- 1260 shall be calculated by $p_{GRP} = T_{SI} * f_{LA,max} / C_{PW,min}$;
- 1261 • the methods and outcome of each step shall be recorded.

1262 **Assignment of verdict:**

1263 The verdict PASS shall be assigned if the calculated probability p_{GRP} is less than 10^{-2} .

1264 The verdict FAIL shall be assigned otherwise.

1265 **Supporting Evidence:**

- 1266 • the authentication mechanism and the interface via which it was accessed;
- 1267 • all test records of the performed test.

1268 **E.3.2.5 Assessment criteria regarding the protection against targeted brute**

1269 **force attacks**

1270 **Assessment objective:**

1271 The assessment covers functional testing of authentication mechanisms that provide an enhanced level of protection and
1272 use authentication factors of the type knowledge against targeted brute force attacks.

1273 **Assessment preparation:**

- 1274 • the product shall be set up in default configuration;
- 1275 • at least one interface, where the authentication mechanism is reachable shall be documented;
- 1276 • the security insurance time (T_{SI}) for this assessment one month ($2,6 * 10^6s$).

1277 **Assessment activities:**

- 1278 • the minimal recommended complexity of passwords accepted by the mechanism ($C_{PW,min}$) shall be
- 1279 determined; e.g. $C_{PW,min} = (26 * 2 + 10)^8$ for minimum 8 characters of upper-case or lower-case letters or
- 1280 numbers.
- 1281 • the maximum sustained login attempt frequency ($f_{LA,max}$) shall be determined; e.g. $f_{LA,max} = (0,1 s)^{-1}$ for 10
- 1282 login attempt per second.
- 1283 • the probability of guessing a completely random password of the minimal recommended complexity (p_{GRP})
- 1284 shall be calculated by $p_{GRP} = T_{SI} * f_{LA,max} / C_{PW,min}$.
- 1285 • the methods and outcome of each step shall be recorded.

1286 **Assignment of verdict:**

1287 The verdict PASS shall be assigned if the calculated probability p_{GRP} is less than 10^{-6} .

1288 The verdict FAIL shall be assigned otherwise.

1289 **Supporting Evidence:**

- 1290 • the authentication mechanism and the interface via which it was accessed;
- 1291 • all test records of the performed test.

E.3.2.6 Assessment criteria regarding the protection against automated brute force attacks

Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a medium level of protection and use authentication factors of the type knowledge against targeted brute force attacks.

Assessment preparation:

- the product shall be set up in default configuration;
- at least one interface, where the authentication mechanism is reachable shall be documented;
- the security insurance time (T_{SI}) for this assessment is one day (86 400 s).

Assessment activities:

- the minimal recommended complexity of passwords accepted by the mechanism ($C_{PW,min}$) shall be determined; e.g. $C_{PW,min} = (26 * 2 + 10)^8$ for minimum 8 characters of upper-case case or lower-case letters or numbers;
- the maximum sustained login attempt frequency ($f_{LA,max}$) shall be determined; e.g. $f_{LA,max} = \frac{5}{5*3s+3600s}$ for 3 seconds per login attempt + a one-hour waiting period after 5 failed login attempts;
- the probability of guessing a completely random password of the minimal recommended complexity (p_{GRP}) shall be calculated by $p_{GRP} = T_{SI} * f_{LA,max} / C_{PW,min}$;
- the methods and outcome of each step shall be recorded.

Assignment of verdict:

The verdict PASS shall be assigned if the calculated probability p_{GRP} is less than 10^{-6} .

The verdict FAIL shall be assigned otherwise.

Supporting Evidence:

- the authentication mechanism and the interface via which it was accessed;
- all test records of the performed test.

E.3.2.7 Assessment criteria regarding the protection against presentation attacks

Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a medium level of protection and use authentication factors of the type inherence against presentation attacks.

Assessment preparation:

- the product shall be set up in default configuration;
- a genuine enrolled biometric template in the corresponding authentication mechanism with credential for authentication shall be created;
- at least one interface, where the authentication mechanism is reachable shall be documented;
- authentication factors shall be fabricated using readily available materials and tools as well as readily available source materials. The fabrication process shall not be longer than *twenty* minutes per authentication factor.

NOTE: Readily available source materials are e.g. fingerprints on everyday items or publicly available photos. Readily available materials and tools are of adhesive tape, printer paper, common printers.

1330 **Assessment activities:**

- 1331 • authentication at the created account shall be attempted using the correct account name, if present, and at least
1332 two fabricated authentication factors tried at least five times with slightly different parameters each;
- 1333 • the outcome and used fabricated authentication factor of each attempt shall be recorded.

1334 **Assignment of verdict:**

1335 The verdict PASS shall be assigned if the authentication mechanism rejects all attempts.

1336 The verdict FAIL shall be assigned otherwise.

1337 **Supporting Evidence:**

- 1338 • description of the performed test
- 1339 • all test records of the performed test

1340 **E.3.2.8 Assessment criteria regarding the protection against elaborate brute**
1341 **force attacks**

1342 **Assessment objective:**

1343 The assessment covers functional testing of authentication mechanisms that provide a high level of protection and use
1344 authentication factors of the type knowledge against targeted brute force attacks.

1345 **Assessment preparation:**

- 1346 • the product shall be set up in default configuration;
- 1347 • at least one interface, where the authentication mechanism is reachable shall be documented;
- 1348 • the security insurance time (T_{SI}) for this assessment is five years ($1,6 * 10^8 s$).

1349 **Assessment activities:**

- 1350 • the minimal recommended complexity of passwords accepted by the mechanism ($C_{PW,min}$) shall be
1351 determined; e.g. $(26 * 2 + 10)^8$ for minimum 8 characters of upper-case case or lower-case letters or
1352 numbers;
- 1353 • the maximum sustained login attempt frequency ($f_{LA,max}$) shall be determined; e.g. $(0,1s)^{-1}$ for 10 login
1354 attempt per second;
- 1355 • the probability of guessing a completely random password of the minimal recommended complexity (p_{GRP})
1356 shall be calculated by $p_{GRP} = T_{SI} * f_{LA,max} / C_{PW,min}$;
- 1357 • the methods and outcome of each step shall be recorded.

1358 **Assignment of verdict:**

1359 The verdict PASS shall be assigned if the calculated probability is less than 10^{-6} .

1360 The verdict FAIL shall be assigned otherwise.

1361 **Supporting Evidence:**

- 1362 • the authentication mechanism and the interface via which it was accessed;
- 1363 • all test records of the performed test.

E.3.2.9 Assessment criteria regarding the protection against automated security token spoofing attacks

Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide a medium level of protection and use authentication factors of the type possession against automated security token spoofing attacks.

Assessment preparation:

- the product shall be set up in default configuration;
- an account in the corresponding authentication mechanism with a security token for authentication shall be created;
- at least one interface, where the authentication mechanism is reachable shall be documented;
- security tokens, that match specifications of the interfaces, via which the authentication mechanism is reachable, shall be prepared or created without using any specific knowledge of the authentication mechanism.

Assessment activities:

- authentication at the created account shall be attempted using the correct account name, if present, and the prepared or created security tokens;
- the outcome and used authentication factor of each attempt shall be recorded.

Assignment of verdict:

The verdict PASS shall be assigned if the authentication mechanism rejects all attempts, except where the used authentication factor exactly matches the configured one.

The verdict FAIL shall be assigned otherwise.

Supporting Evidence:

- description of the performed test;
- all test records of the performed test.

E.3.2.10 Assessment criteria regarding the protection against targeted security token spoofing attacks

Assessment objective:

The assessment covers functional testing of authentication mechanisms that provide an enhanced level of protection and use authentication factors of the type possession against targeted security token spoofing attacks.

Assessment preparation:

- the product shall be set up in default configuration;
- an account in the corresponding authentication mechanism with a security token for authentication shall be created;
- at least one interface, where the authentication mechanism is reachable shall be documented;
- security tokens, shall be prepared or created, which match the specifications of the authentication mechanism.

Assessment activities:

- authentication at the created account shall be attempted using the correct account name, if present, and the prepared or created security tokens;
- the outcome and used authentication factor of each attempt shall be recorded.

1402 **Assignment of verdict:**

1403 The verdict PASS shall be assigned if the authentication mechanism rejects all attempts, except where the used
1404 authentication factor exactly matches the configured one.

1405 The verdict FAIL shall be assigned otherwise.

1406 **Supporting Evidence:**

- 1407 • description of the performed test;
- 1408 • all test records of the performed test.

1409 **E.3.2.11 Assessment criteria regarding the protection against elaborate**
1410 **security token spoofing attacks**

1411 **Assessment objective:**

1412 The assessment covers functional testing of authentication mechanisms that provide a high level of protection and use
1413 authentication factors of the type possession against elaborate security token spoofing attacks.

1414 **Assessment preparation:**

- 1415 • the product shall be set up in default configuration;
- 1416 • an account in the corresponding authentication mechanism with a security token for authentication shall be
1417 created;
- 1418 • at least one interface, where the authentication mechanism is reachable shall be documented;
- 1419 • security tokens, shall be prepared or created, which match the specifications of the authentication mechanism
1420 and use information extracted from the original security token.

1421 **Assessment activities:**

- 1422 • authentication at the created account shall be attempted using the correct account name, if present, and the
1423 prepared or created security tokens;
- 1424 • the outcome and used authentication factor of each attempt shall be recorded.

1425 **Assignment of verdict:**

1426 The verdict PASS shall be assigned if the authentication mechanism rejects all attempts, except where the used
1427 authentication factor exactly matches the configured one.

1428 The verdict FAIL shall be assigned otherwise.

1429 **Supporting Evidence:**

- 1430 • description of the performed test.
- 1431 • all test records of the performed test.

1432 **E.3.2.12 Assessment criteria regarding the protection against replay attacks**

1433 **Assessment objective:**

1434 The assessment covers functional testing of authentication mechanisms that use authentication factors of the type
1435 knowledge or possession (e.g. a session token) against replay attacks.

1436 **Assessment preparation:**

- 1437 • the product shall be set up in default configuration;
- 1438 • the authentication mechanism shall be active;

- 1439 • a communication partner with active authentication mechanisms shall be set up for the product;
- 1440 • a capture and replay tool between product and its communication partner shall be set up;
- 1441 • at least one interface, where the authentication mechanism is reachable shall be documented.

1442 **Assessment activities:**

- 1443 • Initiate a connection between the product and its communication partner.
- 1444 • Use a capture tool to record the transmitted message or transaction data.
- 1445 • Replay (retransmit) the captured message to the product using a suitable tool in place to mimic the original
1446 communication partner.
- 1447 • Record if the product accepts the retransmitted data.

1448 **Assignment of verdict:**

- 1449 The verdict PASS shall be assigned if it is not possible to impersonate as the communication partner.
- 1450 The verdict FAIL shall be assigned otherwise.

1451 **Supporting Evidence:**

- 1452 • description of the performed test;
- 1453 • all test records of the performed test.

1454 **E.3.2.13 Assessment criteria regarding the protection against PitM attacks**

1455 **Assessment objective:**

- 1456 The assessment covers functional testing of authentication mechanisms that use authentication factors of the type
1457 knowledge or possession (e.g. a session token) against PitM attacks.

1458 **Assessment preparation:**

- 1459 • the product shall be set up in default configuration;
- 1460 • the authentication mechanism shall be active;
- 1461 • a communication partner with active authentication mechanisms shall be set up for the product;
- 1462 • a capture and PitM tool between product and its communication partner shall be set up;
- 1463 • at least one interface, where the authentication mechanism is reachable shall be documented.

1464 **Assessment activities:**

- 1465 • Initiate a connection between the product and its communication partner.
- 1466 • Attempt to capture data (consumer credentials, tokens, etc.) with the tool in place and actively intercept
1467 communication to impersonate the communication partner during:
 - 1468 - generation and communication of authentication factors for the communication partner (if not pre-
1469 configured); and
 - 1470 - authentication of the communication partner.
- 1471 • Record if the impersonation as communication partner is successful.

1472 **Assignment of verdict:**

- 1473 The verdict PASS shall be assigned if it is not possible to impersonate as the communication partner.

1474 The verdict FAIL shall be assigned otherwise.

1475 **Supporting Evidence:**

- 1476 • description of the performed test;
- 1477 • all test records of the performed test.

1478 **E.4 confidentiality protection strength**

1479 **E.4.1 CONF-SSM Confidentiality protecting persistent storage for**

1480 **confidential data**

1481 **E.4.1.1 General**

1482 The present document specifies confidentiality protecting secure storage mechanisms' strength, by certain security

1483 properties. Those properties are constructed such that mechanisms of higher strength have the properties of lower

1484 strength mechanisms.

1485 **E.4.1.2 confidential persistent storage strength level basic**

1486 Mechanisms for the confidential persistent storage strength level basic shall encrypt such that decryption is only

1487 possible for the product.

1488 **E.4.1.3 confidential persistent storage strength level normal**

1489 Mechanisms for the confidential persistent storage strength level normal shall encrypt such that decryption is

- 1490 • only possible for the product; and
- 1491 • only performed after a successful authentication.

1492 **E.4.1.4 confidential persistent storage strength level enhanced**

1493 Mechanisms for the confidential persistent storage strength level enhanced shall encrypt supported by hardware, such

1494 that:

- 1495 • decryption is only possible for the product after a successful authentication; and
- 1496 • the extraction of the encryption key is prevented by hardware.

1497 **E.4.1.5 confidential persistent storage strength level strong**

1498 Mechanisms for the confidential persistent storage strength level strong shall prevent the extraction of data by hardware.

E.5 confidentiality protection strength

E.5.1 CONF-COM Communication of confidential data

E.5.1.1 General

The present document specifies the strength of mechanisms to protect the confidentiality of communicated confidential data by their resistance against certain attack types. Those attack types are constructed such that mechanisms of higher strength protect against all attack types required for lower strengths.

E.5.1.2 communication of confidential data protection strength level basic

The communication of confidential data protection strength level basic shall protect against the following attack types:

eavesdropping: An attacker secretly intercepts the communication between the product and another entity or another part of the product.

E.5.1.3 communication of confidential data protection strength level normal

The communication of confidential data protection strength level normal shall protect against the following attack types:

eavesdropping: An attacker secretly intercepts the communication between the product and another entity or another part of the product.

direct identity spoofing attack: An attacker mimics another entity to gain a trust relationship with the product

downgrade of communication protocols attack: An attacker forces to use of a legacy, less secure, communication protocol

E.5.1.4 communication of confidential data protection strength level enhanced

The communication of confidential data protection strength level enhanced shall protect against the following attack types:

eavesdropping: An attacker secretly intercepts the communication between the product and another entity or another part of the product.

person in the middle attack: An attacker secretly alters the communication between the product and another entity or another part of the product to gain a trusted relationship with the involved communication partners without their knowledge.

direct identity spoofing attack: An attacker mimics another entity to gain a trust relationship with the product

downgrade of communication protocols attack: An attacker forces to use of a legacy, less secure, communication protocol

E.5.1.5 communication of confidential data protection strength level strong

The communication of confidential data protection strength level strong shall protect against the following attack types:

eavesdropping: An attacker secretly intercepts the communication between the product and another entity or another part of the product.

person in the middle attack: An attacker secretly alters the communication between the product and another entity or another part of the product to gain a trusted relationship with the involved communication partners without their knowledge.

1536 **direct identity spoofing attack:** An attacker mimics another entity to gain a trust relationship with the product

1537 **downgrade of communication protocols attack:** An attacker forces to use of a legacy, less secure, communication
1538 protocol

1539 E.6 integrity protection strength

1540 E.6.1 INT-SWPCK Software package verification

1541 E.6.1.1 General

1542 The present document specifies software package verification mechanisms' strength, by certain protection measures.
1543 Those measures are constructed such that measures of higher strength typically have less attack vectors than lower
1544 strength measures.

1545 E.6.1.2 software package integrity verification strength level basic

1546 Mechanisms for the software package integrity verification strength level basic shall:

- 1547 • explicitly obtain the confirmation of an authorized entity that the integrity and authenticity of a software
1548 package has been verified by the entity, where the software package's source is determined by the entity; or
- 1549 • explicitly obtain the confirmation of an authorized entity that the authenticity of a software package has been
1550 verified by the entity and use a hash or checksum provided by the entity for the software package to verify its
1551 integrity, where the software package's source is determined by the entity.

1552 E.6.1.3 software package integrity verification strength level normal

1553 Mechanisms for the software package integrity verification strength level normal shall ensure that a software package
1554 has been obtained from a trusted source over a secure communication channel that meets INT.COM.Enhanced.

1555 E.6.1.4 software package integrity verification strength level enhanced

1556 Mechanisms for the software package integrity verification strength level enhanced shall verify the authenticity and
1557 integrity of a software package using cryptographic digital signature verification.

1558 E.6.2 INT-COM Communication of integrity relevant data

1559 E.6.2.1 General

1560 The present document specifies the strength of mechanisms to protect the integrity of communicated integrity relevant
1561 data by their resistance against certain attack types. Those attack types are constructed such that mechanisms of higher
1562 strength protect against all attack types required for lower strengths.

1563 E.6.2.2 communication of integrity relevant data protection strength level basic

1564 The communication of integrity relevant data protection strength level basic shall protect against the following attack
1565 types:

1566 **accidental bit flip:** Accidental change of data by natural causes.

1567 E.6.2.3 communication of integrity relevant data protection strength level normal

1568 The communication of integrity relevant data protection strength level normal shall protect against the following attack
1569 types:

1570 **replay attack:** An attacker intercepts valid transmissions and then retransmits those captured messages to the same
1571 interface to deceive it into performing unauthorized actions.

1572 **accidental bit flip:** Accidental change of data by natural causes.

1573 **direct identity spoofing attack:** An attacker mimics another entity to gain a trust relationship with the product

1574 **downgrade of communication protocols attack:** An attacker forces to use of a legacy, less secure, communication
1575 protocol

1576 E.6.2.4 communication of integrity relevant data protection strength level enhanced

1577 The communication of integrity relevant data protection strength level enhanced shall protect against the following
1578 attack types:

1579 **replay attack:** An attacker intercepts valid transmissions and then retransmits those captured messages to the same
1580 interface to deceive it into performing unauthorized actions.

1581 **person in the middle attack:** An attacker secretly alters the communication between the product and another entity or
1582 another part of the product to gain a trusted relationship with the involved communication partners without their
1583 knowledge.

1584 **accidental bit flip:** Accidental change of data by natural causes.

1585 **direct identity spoofing attack:** An attacker mimics another entity to gain a trust relationship with the product.

1586 **downgrade of communication protocols attack:** An attacker forces to use of a legacy, less secure, communication
1587 protocol.

1588 E.6.2.5 communication of integrity relevant data protection strength level strong

1589 The communication of integrity relevant data protection strength level strong shall protect against the following attack
1590 types:

1591 **replay attack:** An attacker intercepts valid transmissions and then retransmits those captured messages to the same
1592 interface to deceive it into performing unauthorized actions.

1593 **person in the middle attack:** An attacker secretly alters the communication between the product and another entity or
1594 another part of the product to gain a trusted relationship with the involved communication partners without their
1595 knowledge.

1596 **accidental bit flip:** Accidental change of data by natural causes.

1597 **direct identity spoofing attack:** An attacker mimics another entity to gain a trust relationship with the product.

1598 **downgrade of communication protocols attack:** An attacker forces to use of a legacy, less secure, communication
1599 protocol.

1600

Annex F (informative): Relationship between the present document and the requirements of EU Regulation 2024/2847

The present document has been prepared under the Commission's standardisation request C(2025) 618 final to provide one voluntary means of conforming to the requirements of Regulation (EU) No 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

NOTE: The above paragraphs have to be repeated in the Foreword.

The annex shall have a table for a clear indication of correspondence between normative clauses of the standard and the legal requirements aimed to be covered.



It should be evaluated - on the basis of the legal requirements supported and other information given in a harmonised standard - how detailed correspondence can be indicated between the normative elements of the harmonised standard and the legal requirements aimed to be covered. However, where this correspondence is expressed in too general terms, it could lead to a situation where the Commission cannot assess whether the Harmonised Standard satisfies the requirements, which it aims to cover, and subsequently publication of its references in the OJEU according to Article 10(6) of the Regulation is significantly delayed or is not possible at all.

EXAMPLE for a table:

Table A.1: Relationship between the present document and the requirements of EU Regulation 2024/2847

Harmonised Standard ETSI EN 304 634					
Requirement				Requirement Conditionality	
No	Description	Requirements of Regulation	Clause(s) of the present document	U/C	Condition
1					
2					
3					
...					

Key to columns:

Requirement:

No A unique identifier for one row of the table which may be used to identify a requirement.

Description A textual reference to the requirement.

Requirements of Regulation

Identification of article(s) defining the requirement in the Regulation.

Clause(s) of the present document

Identification of clause(s) defining the requirement in the present document unless another document is referenced explicitly.

Requirement Conditionality:

1637	U/C	Indicates whether the requirement is unconditionally applicable (U) or is conditional upon the
1638		manufacturer's claimed functionality of the equipment (C).
1639	Condition	Explains the conditions when the requirement is or is not applicable for a requirement which is
1640		classified "conditional".
1641	NOTE 1: The table cannot indicate direct relationship between the relevant legal requirement and other standards or	
1642	normative clauses contained in other standards.	
1643	NOTE 2: The order of the first and the second columns can be changed.	
1644	NOTE 3: The title of this column can be adapted on the basis of specific needs	
1645	The annex shall have at least the following two warnings.	
1646	(1) A warning stating that presumption of conformity is effective only as long as the reference is maintained in the	
1647	OJEU by the Commission. The following URL-address https://ec.europa.eu/growth/single-market/european-	
1648	standards/harmonised-standards_en to consult the latest list of Harmonised Standards published in the OJEU	
1649	should be provided.	
1650	Presumption of conformity stays valid only as long as a reference to the present document is maintained in the list	
1651	published in the Official Journal of the European Union. Users of the present document should consult frequently the	
1652	latest list published in the Official Journal of the European Union.	
1653	(2) A warning stating that those products or services which are within the scope of a relevant standard may be also	
1654	subject to other Union legislation.	
1655	Other Union legislation may be applicable to the product(s) falling within the scope of the present document.	
1656		

Annex G (informative): Relationship between the present document and the covered/not covered cybersecurity risks

This informative annex is intended to provide the relevant information on the covered/not covered cybersecurity risks based on the assessment of cybersecurity risks performed during the standard's development.

TBD

Editor's Note: The relationship between the present document and the covered/not covered cybersecurity risks has to be finalized by the group. They will be included in the present document when the discussion on them will be completed

Annex H (informative): Change history

Version	Information about changes
0.0.1	Early draft
0.0.2	Early draft presented the 2 nd September 2025
0.1.0	Stable draft uploaded the 5 th December 2025
0.2.0	Mature draft presented the 27 th January 2026
0.2.2	Editorial changes

History

Version	Date	Status
V0.2.2	February 2026	Clean-up done by <i>editHelp!</i> E-mail: mailto:edithelp@etsi.org